Thiết kế phần mềm

Hệ thống quản lý đặt lịch khám và khám bệnh từ xa
Phòng khám ngoại trú nhiều chi nhánh

Topic 2 Hồ sơ ứng dụng Visual Studio Phiên bản 2.3 Ngày 13 tháng 10 năm 2026

Tài liệu quy định kiến trúc, module, CSDL, API, bảo mật, xử lý tranh chấp và vận hành Topic 2. Phương án chốt: ứng dụng desktop WPF cho Windows phát triển bằng Visual Studio, C#/.NET 10, XAML/MVVM; backend ASP.NET Core Web API (.NET 10), PostgreSQL 17. Daily video qua WebView2 cần kiểm chứng; Mailgun gửi Email và SMS mô phỏng.

Nhóm thực hiện gồm bốn vai trò M1 đến M4 theo handbook học phần. Các mã này biểu thị trách nhiệm thực hiện và kiểm tra trong backlog.

Mục lục

1 Mục tiêu và căn cứ thiết kế....4
2 Quyết định kiến trúc....4
ADR-01 ASP.NET Core 10 + C#/.NET 10 + WPF....4
ADR-02 PostgreSQL 17....4
ADR-03 Giao diện Windows WPF XAML/MVVM....4
ADR-04 OAuth2 PKCE cho native public client....4
ADR-05 Daily private rooms và SDK....5
ADR-06 Mailgun Email và SmsMockAdapter....5
ADR-07 Outbox và queue PostgreSQL....5
ADR-08 Phát hành app và vận hành API HTTPS....5
ADR-09 Mã hóa trường và backup bằng khóa tách biệt....5
ADR-10 Audit trong PostgreSQL và digest ngoài máy chủ....6
ADR-11 Bốn vai trò M1 đến M4 và Scrum bốn sprint....6
3 Kiến trúc theo 4 cộng 1 view....6
4 Thiết kế phân hệ....11
4.1 Identity....12
4.2 Patient....12
4.3 Scheduling....12
4.4 Appointment....12
4.5 Encounter....13
4.6 Clinical....13
4.7 Telehealth....13
4.8 Notification....13
4.9 Audit....14
5 Thiết kế dữ liệu....16
5.1 Chuẩn hóa và bội số....16
5.2 Schema và ràng buộc....23
5.3 Index và khóa....29
6 Hợp đồng API....30
6.1 Luồng OAuth2 và phiên....33
6.2 Error taxonomy và recovery....33
7 Thiết kế luồng và tranh chấp....33
7.1 Đặt lịch....34
7.2 Đổi lịch....35
7.3 Tiếp nhận và bắt đầu....36
7.4 Hoàn tất lâm sàng....37
7.5 Đọc và xuất PHI....38
7.6 Tham gia và nối lại video....39
7.7 Thông báo và callback....40
7.8 Đóng video khi provider lỗi....41

8 Bảo mật và riêng tư....42
8.1 Quyền theo quan hệ....42
8.2 Dữ liệu và khóa....42
8.3 WPF, API và tệp đính kèm....42
8.4 Video và webhook....42
8.5 Audit và log vận hành....42
9 Thiết kế giao diện....43
UI-01 Tài khoản....43
UI-02 Hồ sơ và sức khỏe....43
UI-03 Tìm lịch trống....43
UI-04 Lịch hẹn....43
UI-05 Lịch bác sĩ....44
UI-06 Tiếp nhận....44
UI-07 Khám và đơn nháp....44
UI-08 Kết quả và hiệu chỉnh....45
UI-09 Video....45
UI-10 Thông báo....45
UI-11 Quản trị....45
UI-12 Nhật ký và vận hành....46
10 Triển khai và vận hành....46
10.1 Runbook WPF và backend API....46
10.2 Giám sát và phục hồi....47
11 Kiểm thử thiết kế và điểm giới hạn....47
Tài liệu tham chiếu....47

1 Mục tiêu và căn cứ thiết kế

Kiến trúc client–server: ứng dụng Windows WPF (XAML/MVVM) giao tiếp HTTPS với ASP.NET Core Web API; modular monolith phân tầng và PostgreSQL 17 đặt phía máy chủ. WPF chỉ quản lý UI, ViewModel, typed HttpClient và state tạm; domain, authorization, transaction và audit thuộc backend. Xử lý nhiều aggregate được điều phối tại application layer.

Bảng 1 Driver kiến trúc

Driver	Tác động thiết kế
Đa chi nhánh và không overbooking	PostgreSQL ranges/exclusion; scope server; doctor và patient locks.
FINAL bất biến và audit bắt buộc	Encrypted payload; guards; addenda và RX versions; audit cùng transaction ghi.
Video và notification phụ thuộc provider	Private tokens; access_closed; outbox, leases và UNKNOWN.
Bốn vai trò nhóm và demo app Windows desktop	WPF WPF XAML/MVVM client + ASP.NET Core modular monolith API; worker/scheduler và phát hành gói app tái lập.
Truy vết và unit coverage tối thiểu 60%	Domain policies độc lập, Clock interface, contract tests và CI report.

2 Quyết định kiến trúc

ADR-01 ASP.NET Core 10 và C#/.NET 10 trong Visual Studio

Quyết định Dùng C#/.NET 10 cho WPF desktop và ASP.NET Core Web API .NET 10 cho backend trong một Visual Studio solution.

Căn cứ Visual Studio hỗ trợ WPF XAML Designer, MVVM, DI và debug C#/.NET; ASP.NET Core/EF Core/Npgsql đáp ứng API, transaction, bảo mật và lưu trữ.

Phương án đã so sánh WinForms dễ làm form nhưng tổ chức MVVM khó hơn; .NET MAUI phù hợp đa nền tảng nhưng nhóm chỉ chọn Windows; website Laravel không đúng định hướng ứng dụng desktop.

Hệ quả Sinh, xác minh và commit packages.lock.json trước khi bật restore --locked-mode; build với .NET SDK 10 tương thích Visual Studio; migration bằng EF Core; lưu log PR/CI và kiểm tra trên máy Windows thật trước demo.

Truy vết SR-01, SR-02, NFR-14, NFR-16

ADR-02 PostgreSQL 17

Quyết định PostgreSQL 17.

Căn cứ Range, exclusion constraint và khóa hàng hỗ trợ lịch đa chi nhánh và tranh chấp thực.

Phương án đã so sánh SQLite không đủ mô phỏng khóa nhiều giao dịch và exclusion; SQL Server là tùy chọn nhưng thay PostgreSQL sẽ phá DDL và truy vết hiện có.

Hệ quả Cần quyền cài btree_gist khi migrate; kiểm thử integration trên PostgreSQL cùng major.

Truy vết BR-07, BR-08, BR-09, NFR-02

ADR-03 Giao diện desktop WPF XAML/MVVM

Quyết định WPF Window/Page/UserControl, MVVM bằng CommunityToolkit.Mvvm, Command, ObservableCollection, typed HttpClient; phát hành Windows 10/11.

Căn cứ Nhóm xác nhận WPF cho ứng dụng desktop chạy Windows bằng Visual Studio; tận dụng binding, DataGrid, Validation và UI Automation.

Phương án đã so sánh Web SSR không phải desktop app; WinForms thích hợp form đơn giản nhưng ít thuận lợi hơn cho MVVM; MAUI không cần thiết vì MVP không phát hành Android.

Hệ quả **Không lưu PHI trong file/Registry/cache/log; token bảo vệ bằng Windows DPAPI (ProtectedData) phạm vi CurrentUser, khóa session theo user; nháp chỉ RAM; xóa dữ liệu phiên khi logout/đóng app.**

Truy vết UI-01, UI-07, UI-09, NFR-13

ADR-04 OAuth2 Authorization Code PKCE cho native public client

Quyết định **OpenIddict trên ASP.NET Core Identity Server; WPF desktop là public OAuth2 client, Authorization Code + PKCE S256 qua system browser và loopback redirect URI 127.0.0.1:cổng_động.**

Căn cứ **WPF giữ state/code_verifier trong RAM, kiểm tra callback tới loopback địa chỉ/cổng được allowlist và dùng PKCE; token cục bộ mã hóa DPAPI, API xác thực Bearer và kiểm tra quyền tài nguyên.**

Phương án đã so sánh **BFF cookie hợp với website; password grant/implicit grant không phù hợp desktop public client; WebView2 nhúng form đăng nhập không phải lựa chọn chính.**

Hệ quả **Không đóng gói client_secret; đăng ký public client, loopback redirects và chống code interception; refresh/revoke phía server; xóa DPAPI token trên logout.**

Truy vết SR-02, FR-01.2, NFR-04, NFR-05

ADR-05 Daily private rooms và SDK

Quyết định Daily private rooms và SDK.

Căn cứ **API cấp Daily private room/token theo appointment/user_id; cửa sổ video nhúng Microsoft Edge WebView2 với WebRTC và cơ chế yêu cầu quyền camera/micro của Windows.**

Phương án đã so sánh Tự WebRTC/TURN tăng vận hành; Jitsi công khai không đáp ứng quyền phòng cần kiểm soát.

Hệ quả **Spike kỹ thuật bắt buộc: WebView2 Runtime, camera/mic permission, Daily SDK, đổi mạng, reconnect và đóng phiên trên Windows 10/11; kết quả chưa được xác minh.**

Truy vết FR-07.2, FR-07.4, FR-07.5, NFR-10

ADR-06 Mailgun Email và SmsMockAdapter

Quyết định Mailgun Email và SmsMockAdapter.

Căn cứ Email có bằng chứng provider và webhook; SMS mô phỏng đúng phạm vi demo.

Phương án đã so sánh SMTP thuần thiếu đối soát trạng thái giao; SMS thật cần chi phí và đăng ký thương hiệu ngoài demo.

Hệ quả SMS luôn SIMULATED; Email ACCEPTED chỉ đổi DELIVERED bằng callback xác thực.

Truy vết FR-08.1, FR-08.6, BR-37

ADR-07 Outbox và queue PostgreSQL

Quyết định Outbox và queue PostgreSQL.

Căn cứ Lưu sự kiện cùng giao dịch; một worker và scheduler một phút đủ quy mô demo.

Phương án đã so sánh Redis tăng thành phần; gửi đồng bộ làm lỗi provider ảnh hưởng đặt lịch.

Hệ quả Queue có lease và retry hữu hạn; UNKNOWN không retry mù; kiểm tra version tại thời điểm cho phép gửi.

Truy vết SR-04, BR-34, BR-36, NFR-11

ADR-08 Phát hành app và vận hành API HTTPS

Quyết định **Phát hành WPF trên Windows bằng MSIX hoặc installer có chữ ký; backend ASP.NET Core API/.NET Worker/PostgreSQL 17 chạy Linux Docker Compose với reverse proxy HTTPS.**

Căn cứ **App cài đặt từ Visual Studio hoặc gói phát hành; backend chạy container Kestrel qua Nginx TLS; DB chỉ trong private network; chưa yêu cầu public web frontend.**

Phương án đã so sánh **Chạy dữ liệu SQLite cục bộ không cho nhiều phòng khám đồng bộ; hosting PHP không phù hợp API .NET; Kubernetes vượt mức MVP.**

Hệ quả **Lưu package installer/MSIX SHA, phiên bản .NET Desktop Runtime/WebView2 Runtime, URL API HTTPS thật, chứng cứ cài mới/nâng cấp/gỡ; không đóng gói server secret.**

Truy vết SR-03, NFR-01, NFR-03, NFR-14

ADR-09 Mã hóa trường và backup bằng khóa tách biệt

Quyết định Mã hóa trường và backup bằng khóa tách biệt.

Căn cứ **Mã hóa AES-256-GCM bằng thư viện mật mã .NET với key id trong key ring bên ngoài DB; restic mã hóa backup trước khi đưa lên kho riêng tư.**

Phương án đã so sánh Chỉ mã hóa ổ đĩa không bảo vệ dump; tự viết thuật toán không được sử dụng.

Hệ quả Key ring có key_id, khóa cũ giữ cho đọc/restore; khóa nằm ngoài DB và Git, bản phục hồi khóa riêng.

Truy vết NFR-07, NFR-09, FR-09.6

ADR-10 Audit trong PostgreSQL và digest ngoài máy chủ

Quyết định Audit trong PostgreSQL và digest ngoài máy chủ.

Căn cứ Ghi PHI audit trước trả dữ liệu hoặc cùng giao dịch ghi; app role không sửa/xóa.

Phương án đã so sánh Chỉ log file dễ thiếu liên kết; blockchain không cần thiết cho demo.

Hệ quả Chuỗi HMAC theo ngày có khóa audit riêng; digest sao chép sang kho ngoài máy chủ; DBA vẫn là đặc quyền hạ tầng.

Truy vết FR-09.1, FR-09.3, BR-40, BR-41

ADR-11 Bốn vai trò M1 đến M4 và Scrum bốn sprint

Quyết định Bốn vai trò M1 đến M4 và Scrum bốn sprint.

Căn cứ Phân công theo handbook, story có Gherkin và review chéo; mỗi sprint có đầu ra chạy được.

Phương án đã so sánh Phân theo chín module riêng lẻ dễ tạo silo; chia sáu người từ README không thay thế quy định học phần.

Hệ quả **M1 điều phối/thiết kế API; M2 backend ASP.NET Core và database; M3 giao diện WPF và video WebView2; M4 FlaUI/test/CI/installer; mọi thành viên có Issues, commits và PR reviews.**

Truy vết SR-06, NFR-15, NFR-16

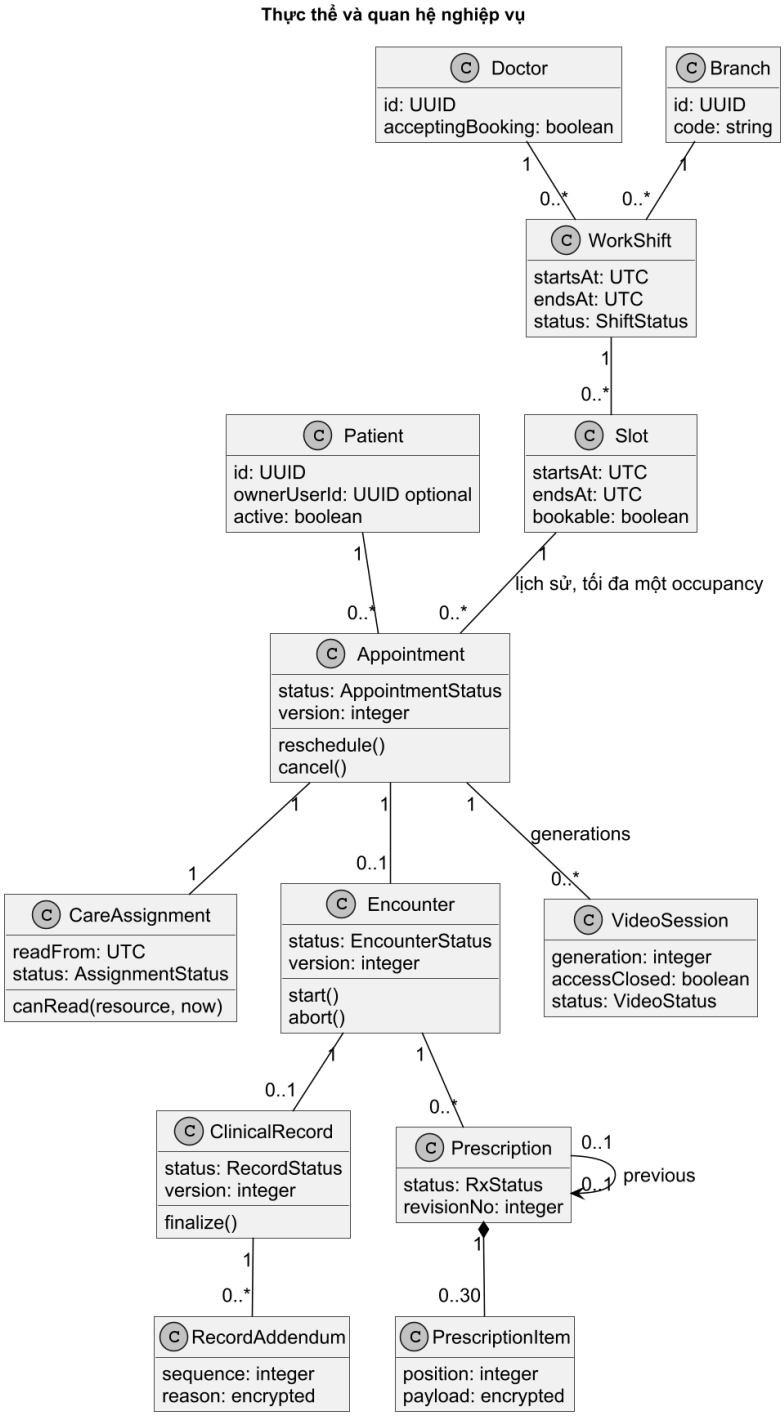
3 Kiến trúc theo 4 cộng 1 view

Bảng 2 Mapping các view và kịch bản

View	Mô hình và trách nhiệm	Kịch bản kiểm chứng
Logical	UML-CLASS-DOMAIN, ERD; aggregate, assignment và trạng thái	UC-09, UC-35, UC-30; TC-X01, TC-X20
Development	UML-PKG, UML-COMP-CORE; module và lớp code	NFR-16; review import/dependency và rule dùng chung
Process	UML-SEQ-BOOK, FINALIZE, NOTIFY; đồng thời, worker, failure	TC-X04, TC-X22, TC-X30, TC-X33
Physical	UML-DEPLOY; node, network, storage và provider	NFR-14, TC-N09, TC-X35
Scenarios	UC và activity trong SRS; thử xuyên chín phân hệ	TC-X23, TC-X26, TC-X27, demo thành công và failure

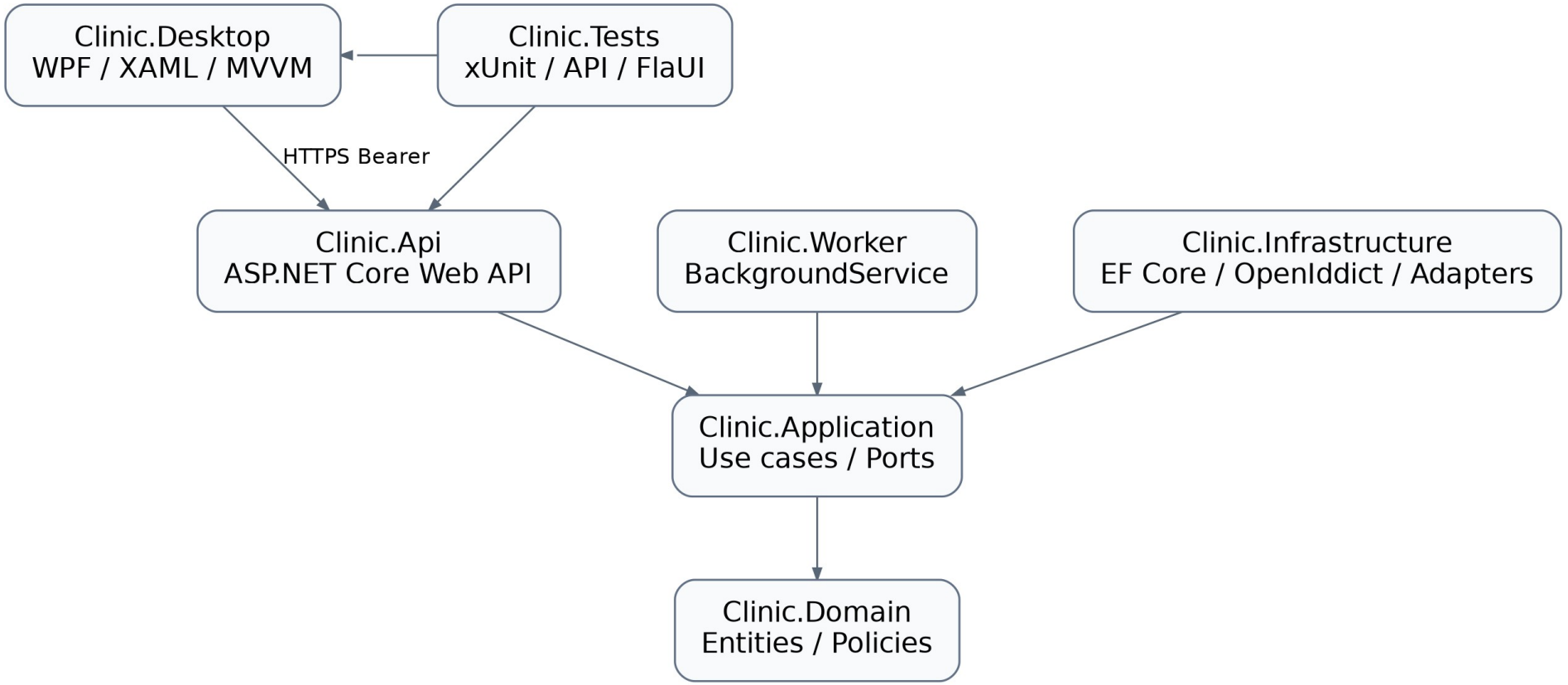
Logical view đặt Patient là hồ sơ tổ chức, Appointment là công suất và Encounter là hoạt động thực tế. CareAssignment giữ căn cứ quyền. ClinicalRecord và Prescription có bất biến riêng. Các thực thể provider không mang vai trò bác sĩ hay quyền lâm sàng.

Hình 1 Thực thể và quan hệ nghiệp vụ UML-CLASS-DOMAIN

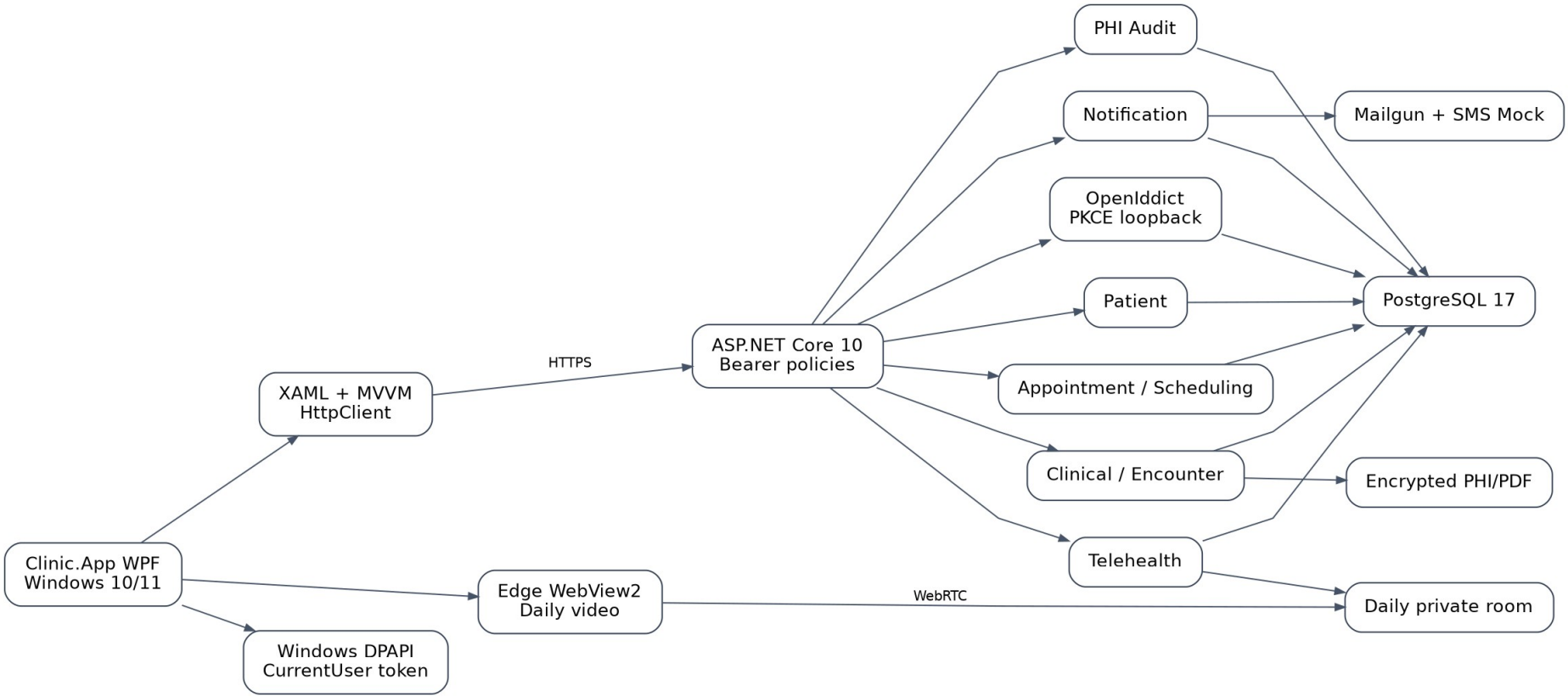


Development view: Clinic.Desktop WPF Views chỉ bind ViewModels (CommunityToolkit.Mvvm) và gọi typed HttpClient, không kết nối DB trực tiếp. API Controllers/Middleware xác thực và ủy quyền, Application điều phối, Domain giữ invariants, Infrastructure chứa EF Core cho CRUD theo Entity/DbContext và ADO.NET (Npgsql) cho câu lệnh/transaction khóa dòng, advisory lock, exclusion-constraint handling, outbox lease, OpenIddict và provider adapters.

Hình 2 Tổ chức mã nguồn UML-PKG

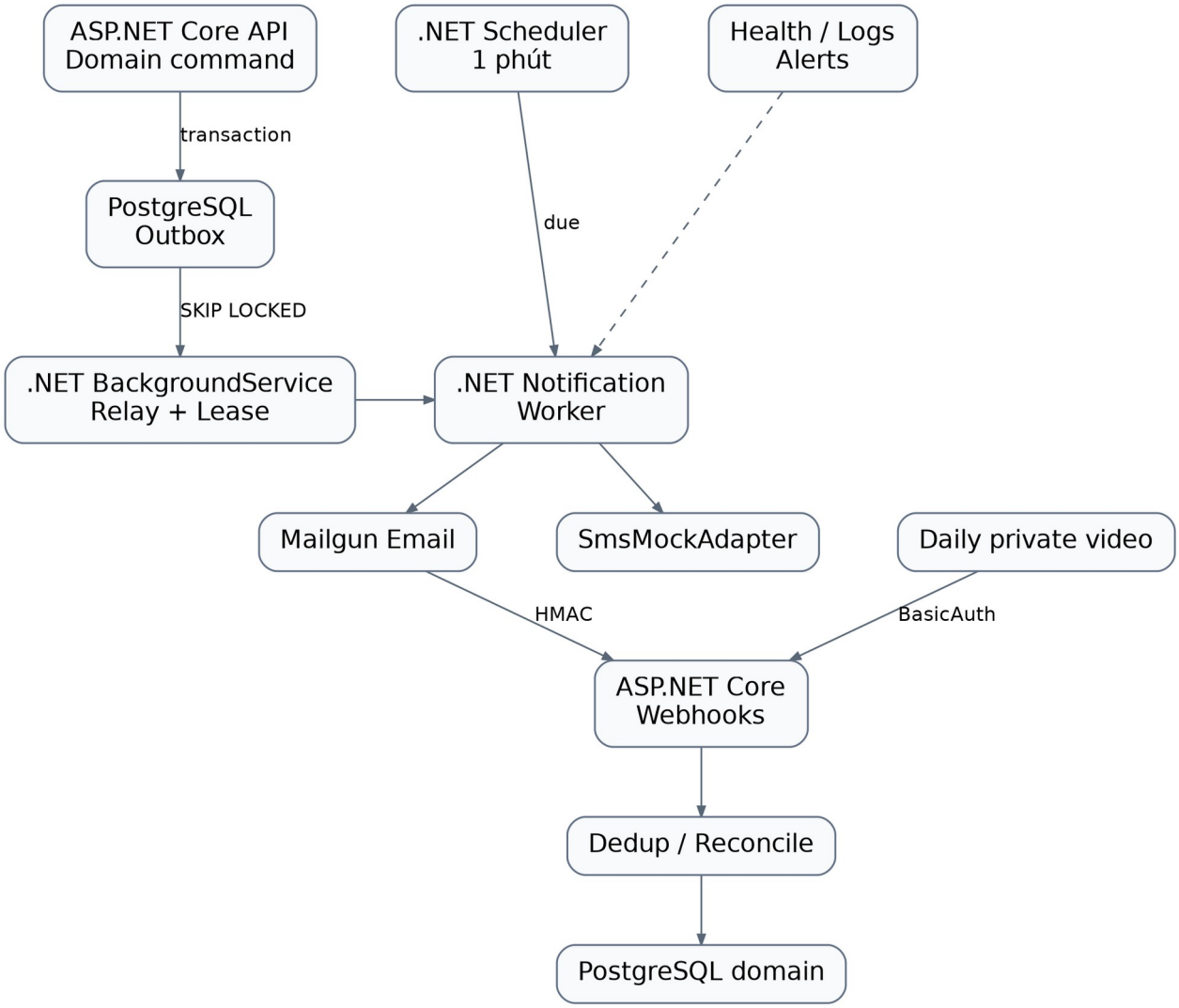


Hình 3 Module và phụ thuộc được phép UML-COMP-CORE



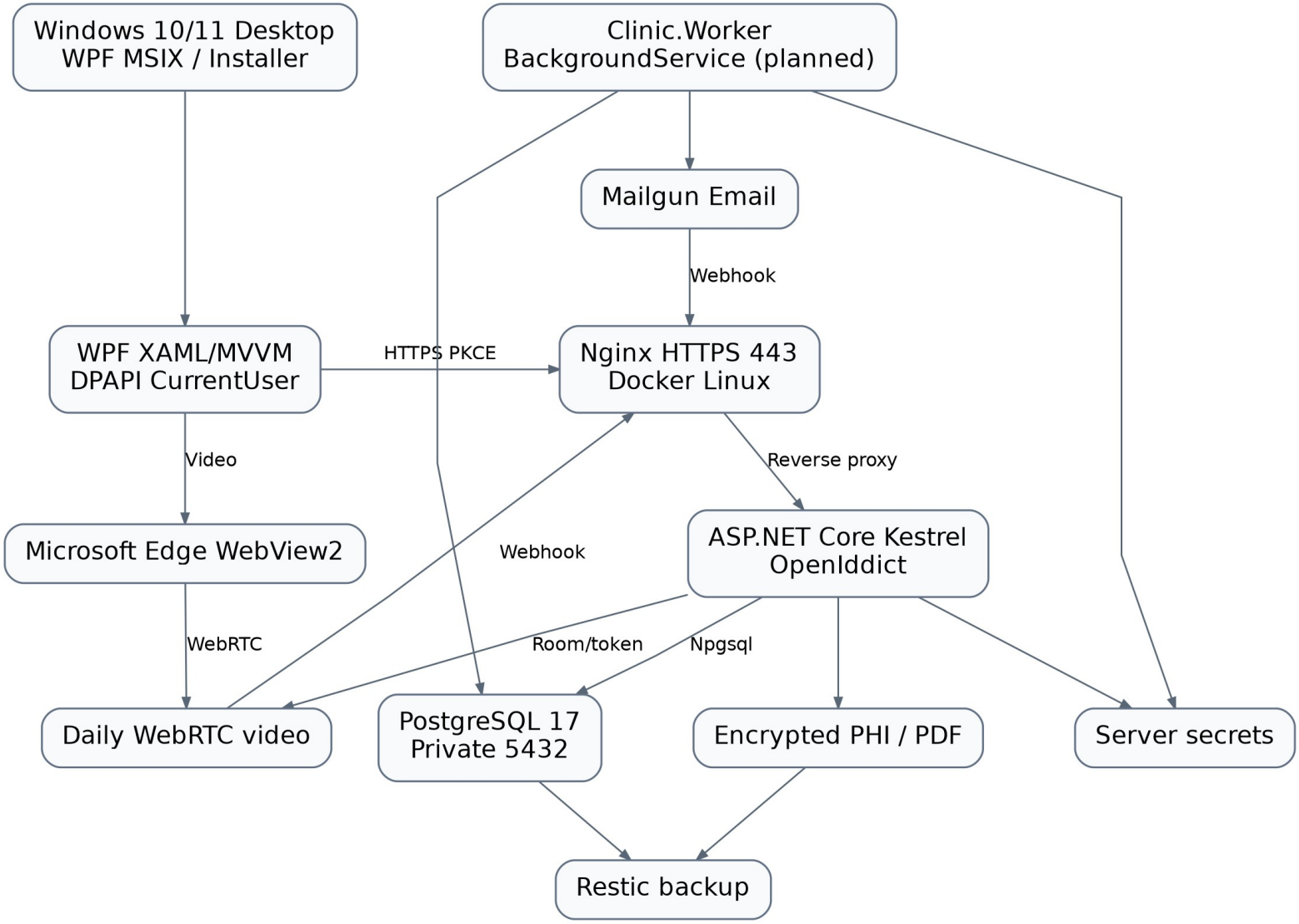
Process view: API Kestrel xử lý request, PostgreSQL READ COMMITTED + lock/exclusion để chống trùng, .NET Worker xử lý outbox/scheduler. WPF async Command chống gửi lặp, Idempotency-Key và version; dùng CancellationToken và retry có giới hạn; provider không chạy trong DB transaction.

Hình 4 Xử lý nền và dịch vụ ngoài UML-COMP-ASYNC



Physical view: WPF chạy trên Windows 10/11, HTTPS tới reverse proxy và API (Linux Docker); PostgreSQL/worker/scheduler nằm trong network nội bộ. Daily media qua Microsoft Edge WebView2 sau consent; backend chỉ cấp quyền phòng/token và không ghi hình. Installer không chứa khóa bí mật.

Hình 5 Triển khai WPF Windows và ranh giới mạng UML-DEPLOY



4 Thiết kế phân hệ

4.1 Identity

Trách nhiệm Tài khoản xác thực và phân quyền. IdentityService, SessionController, CurrentActorPolicy.

Dữ liệu sở hữu app_users, user_branches, patient_link_verifications, idempotency_records

Giao diện và phụ thuộc Patient nhận owner đã xác minh; mọi service nhận RequestContext chỉ đọc.

Biên giao dịch Khóa target app_users khi đổi quyền; authz_version tăng, revoke token/phiên cùng thay đổi.

Lỗi và phục hồi 401/403/429; lỗi identity không bypass.

API register, verifyEmail, resendVerification, logout, changePassword, requestPasswordReset, resetPassword, listStaff, createStaff, updateStaff, oauthAuthorize, oauthToken, oauthRevoke

Yêu cầu FR-01.1, FR-01.2, FR-01.3, FR-01.4, FR-01.5, FR-01.6, FR-01.7, FR-01.8

4.2 Patient

Trách nhiệm Quản lý hồ sơ bệnh nhân. PatientService, HealthProfileService, PatientPolicy.

Dữ liệu sở hữu patients, health_profiles, health_profile_versions

Giao diện và phụ thuộc Appointment kiểm tra active; Clinical đọc phần chuyên môn qua CarePolicy/Audit.

Biên giao dịch Khóa patient và health_profile; ghi version snapshot và audit cùng transaction.

Lỗi và phục hồi 404 scope;409owner/version;503audit; tự khai và chuyên môn tách riêng.

API searchPatients, createPatient, getPatient, updatePatient, deactivatePatient, requestLinkVerification, linkPatientAccount, getHealthProfile, updateSelfHealth, verifyHealth, listPatientRecords

Yêu cầu FR-02.1, FR-02.2, FR-02.3, FR-02.4, FR-02.5, FR-02.6, FR-02.7

4.3 Scheduling

Trách nhiệm Quản lý bác sĩ chuyên khoa và lịch làm việc. ShiftService, SlotQuery, ScheduleConflictPolicy.

Dữ liệu sở hữu branches, specialties, doctors, doctor_branches, work_shifts, slots

Giao diện và phụ thuộc Appointment gọi checkBookable; không chỉnh ca trực tiếp từ Notification.

Biên giao dịch Doctor advisory lock; exclusions và khoảng cách 60 phút; tạo slots trong transaction công bố.

Lỗi và phục hồi 409time/buffer;422breaks/hours; ca tham chiếu immutable time.

API listBranches, createBranch, updateBranch, listSpecialties, createSpecialty, updateSpecialty, listDoctors, createDoctor, updateDoctor, listShifts, createShift, updateShift, stopShift, listSlots, listAppointments, createCoordination

Yêu cầu FR-03.1, FR-03.2, FR-03.3, FR-03.4, FR-03.5, FR-03.6

4.4 Appointment

Trách nhiệm Đặt lịch đổi lịch và hủy lịch. AppointmentService, CoordinationService.

Dữ liệu sở hữu appointments, appointment_history, care_assignments, coordination_requests

Giao diện và phụ thuộc Dùng Scheduling/Patient; phát domain event cho Notification và Telehealth.

Biên giao dịch Doctor/patient locks, appointment row, exclusion/unique, key/history/assignment/outbox cùng transaction.

Lỗi và phục hồi 409slot/stale;422window; provider không ở transaction.

API listSlots, listAppointments, bookAppointment, getAppointment, getAppointmentHistory, rescheduleAppointment, cancelAppointment, createCoordination

Yêu cầu FR-04.1, FR-04.2, FR-04.3, FR-04.4, FR-04.5, FR-04.6

4.5 Encounter

Trách nhiệm Tiếp nhận và quản lý lượt khám. EncounterService, QueueQuery.

Dữ liệu sở hữu encounters

Giao diện và phụ thuộc Clinical finalize phối hợp cùng transaction coordinator; Telehealth gọi checkIn/start.

Biên giao dịch Một encounter/appointment; một IN_PROGRESS/doctor; actor row và doctor lock khi start.

Lỗi và phục hồi 409busy/state/stale; cancelcheckin riêng ABORTED.

API checkInDirect, markNO_SHOW, listEncounters, getEncounter, cancelCheckIn, startEncounter, abortEncounter, acceptVideoPatient

Yêu cầu FR-05.1, FR-05.2, FR-05.3, FR-05.4, FR-05.5, FR-05.6, FR-05.7, FR-05.8

4.6 Clinical

Trách nhiệm Khám bệnh bệnh án và đơn thuốc điện tử. ClinicalService, PrescriptionValidator, ResultRenderer.

Dữ liệu sở hữu clinical_records, record_addenda, prescriptions, prescription_items, medications, private_artifacts

Giao diện và phụ thuộc CarePolicy+Audit bắt buộc; dùng EncounterService trong finalize; storage private.

Biên giao dịch Khóa encounter/record/RX; validate dị ứng; final/audit/assignment cùng commit; provider ngoài giao dịch.

Lỗi và phục hồi 422fields/allergy;409version;503audit; FINAL và RX gốc bất biến.

API getRecordDraft, saveRecordDraft, savePrescriptionDraft, listMedications, finalizeEncounter, getClinicalRecord, listAddenda, createAddendum, downloadRecord, getPrescription, revisePrescription, downloadPrescription

Yêu cầu FR-06.1, FR-06.2, FR-06.3, FR-06.4, FR-06.5, FR-06.6, FR-06.7, FR-06.8

4.7 Telehealth

Trách nhiệm Khám bệnh từ xa qua video. TelehealthService, VideoProvider interface, DailyAdapter.

Dữ liệu sở hữu video_sessions, video_participants

Giao diện và phụ thuộc Đọc appointment version; start qua Encounter; đóng quyền qua sự kiện terminal.

Biên giao dịch DB state trước network; room generation; pendingcleanup; sự kiện client không cấp quyền.

Lỗi và phục hồi 503provider;409terminal;422window; không tự finalize.

API joinVideo, getVideoState, videoClientEvent, acceptVideoPatient, endVideo, dailyWebhook

Yêu cầu FR-07.1, FR-07.2, FR-07.3, FR-07.4, FR-07.5, FR-07.6, FR-07.7

4.8 Notification

Trách nhiệm Xác nhận và nhắc lịch SMS Email. OutboxRelay, NotificationWorker, MailgunAdapter, SmsMockAdapter.

Dữ liệu sở hữu notifications, notification_attempts, notification_configs, outbox_events, webhook_receipts

Giao diện và phụ thuộc Consume metadata event; query appointment version; không gọi Clinical.

Biên giao dịch SKIPLOCKED và lease; authorize under appointment lock; network sau commit; callback persistdedup trướcACK.

Lỗi và phục hồi UNKNOWN không retry mù;3 attempts; signature failure401; SMS mô phỏng SIMULATED.

API listNotifications, reconcileNotification, getNotificationConfig, updateNotificationConfig, mailgunWebhook

Yêu cầu FR-08.1, FR-08.2, FR-08.3, FR-08.4, FR-08.5, FR-08.6

4.9 Audit

Trách nhiệm Bảo mật và nhật ký truy cập bệnh án. AuditService, AuditQuery, AlertEvaluator, BackupRunReporter.

Dữ liệu sở hữu audit_events, audit_chain_heads, security_events, access_alerts, backup_runs

Giao diện và phụ thuộc đọc PHI audit riêng trước trả; ghi PHI cùng transaction; hạ tầng backupCLI tách khỏi API.

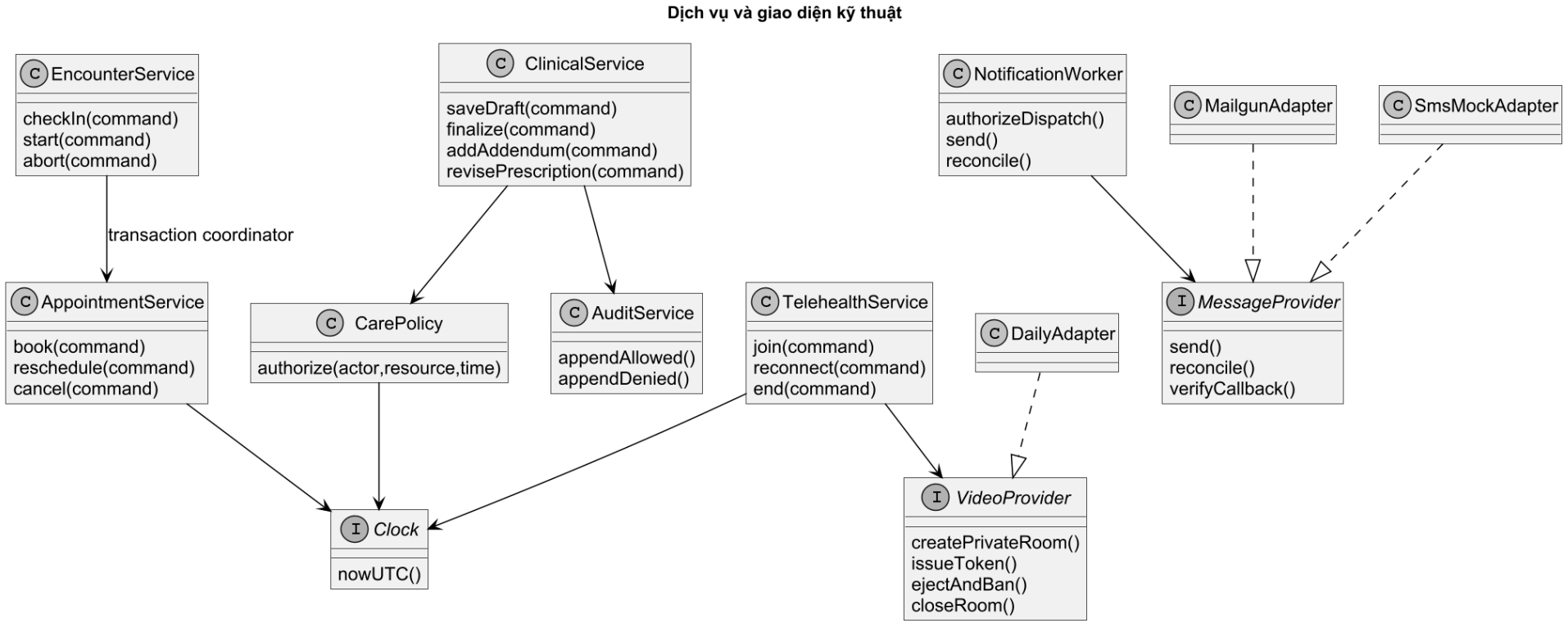
Biên giao dịch Audithead lock; appendHMAC; role app không sửa/xóa; securitylog lookup/export.

Lỗi và phục hồi 503audit không PHI; alert không tự khóa; backup/restore lỗi giữ hệ cũ.

API getHealthProfile, listPatientRecords, getRecordDraft, getClinicalRecord, listAuditEvents, exportAudit, listAccessAlerts, acknowledgeAccessAlert, healthLive

Yêu cầu FR-09.1, FR-09.2, FR-09.3, FR-09.4, FR-09.5, FR-09.6, FR-09.7

Hình 5 Dịch vụ và giao diện kỹ thuật UML-CLASS-SERVICES



5 Thiết kế dữ liệu

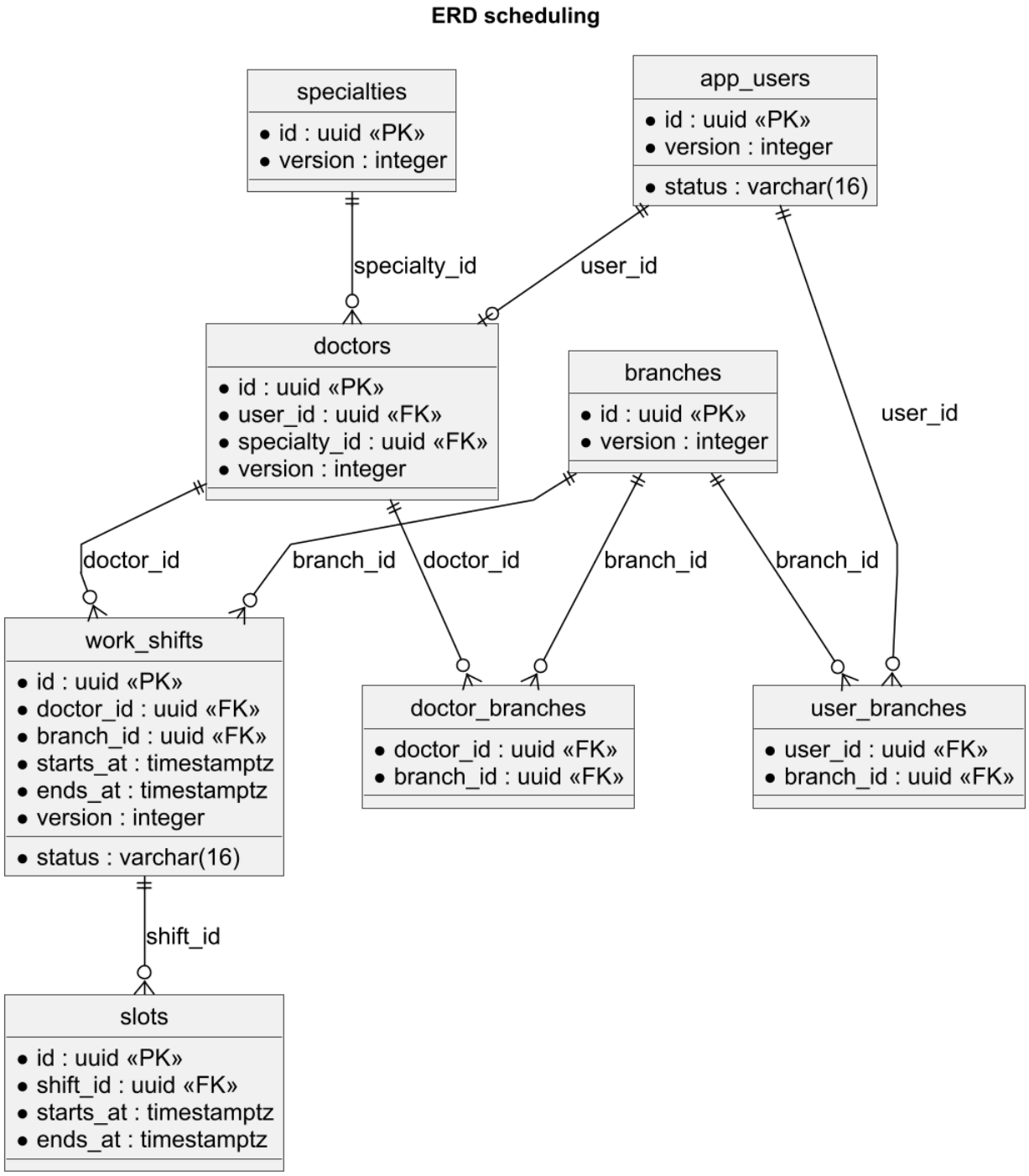
Mô hình vật lý gồm 36 bảng domain PostgreSQL; các bảng OpenIddict (applications, authorizations, scopes, tokens) và Identity/worker do EF Core migrations tạo, UUID nhất quán với app_users. Dữ liệu y tế và tệp mã hóa ở application layer; không dùng session BFF, không trả PHI vào log client hoặc storage không bảo vệ.

5.1 Chuẩn hóa và bội số

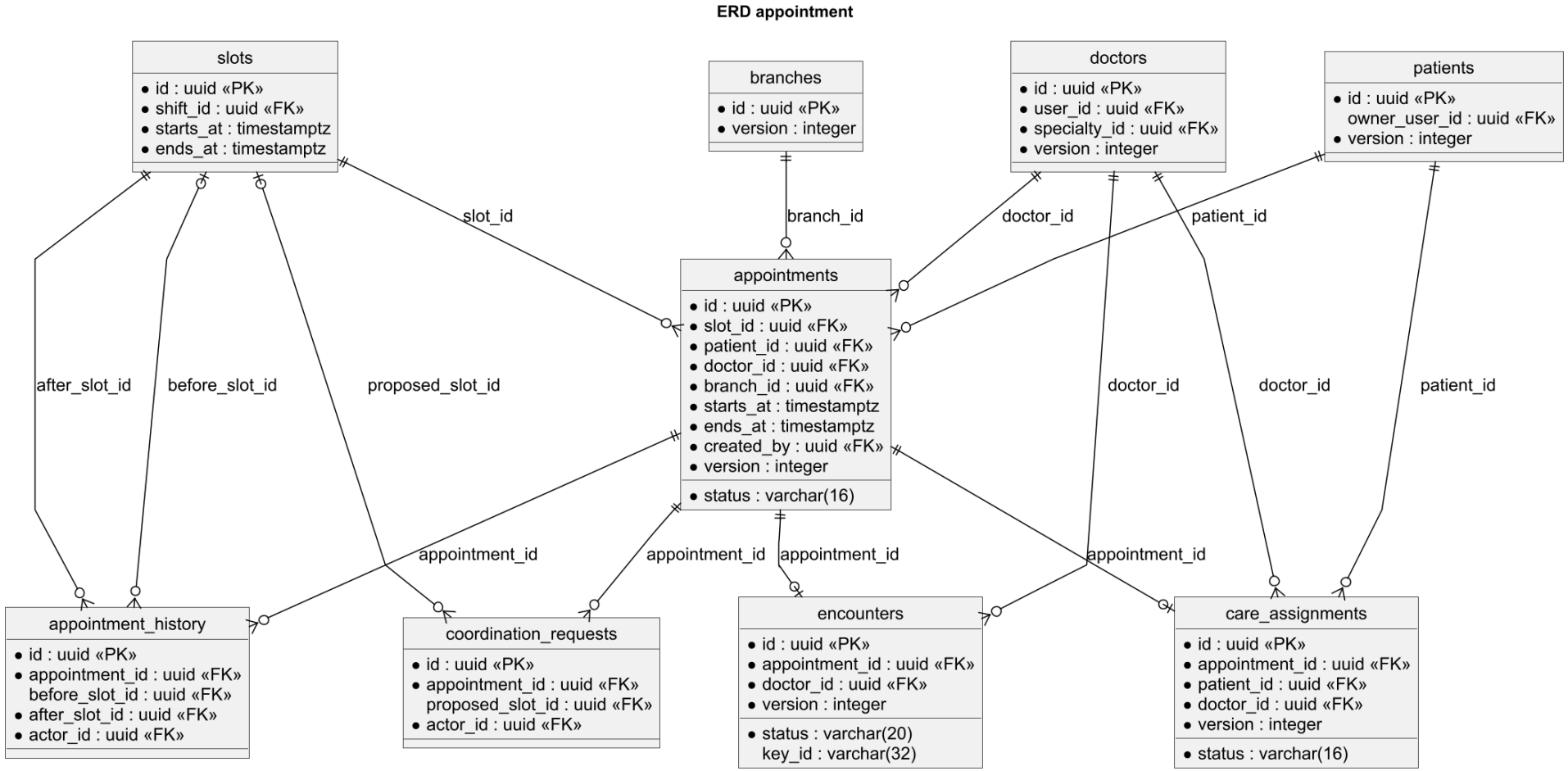
Branch và Doctor là danh mục tham chiếu, doctor_branches và user_branches xử lý nhiều-nhiều. Một Patient có nhiều Appointment; một Slot có nhiều Appointment trong lịch sử nhưng tối đa một occupancy đang hiệu lực. Appointment có một CareAssignment và tối đa một Encounter. Encounter có tối đa một bệnh án gốc, nhiều addenda gián tiếp và chuỗi Prescription. Một Prescription có tối đa30 item; một ISSUED hiện hành và một DRAFT mỗi Encounter.

Mỗi Notification là một logicalevent/kênh/mốc/version có tối đa ba attempt. VideoSession có generation, hai VideoParticipant unique theo role, nhiều generation lịch sử nhưng tối đa một phiên chưa terminal. AuditEvent append-only tham chiếu metadata; không giả định FK từ resource_id đa hình đến mọi bảng.

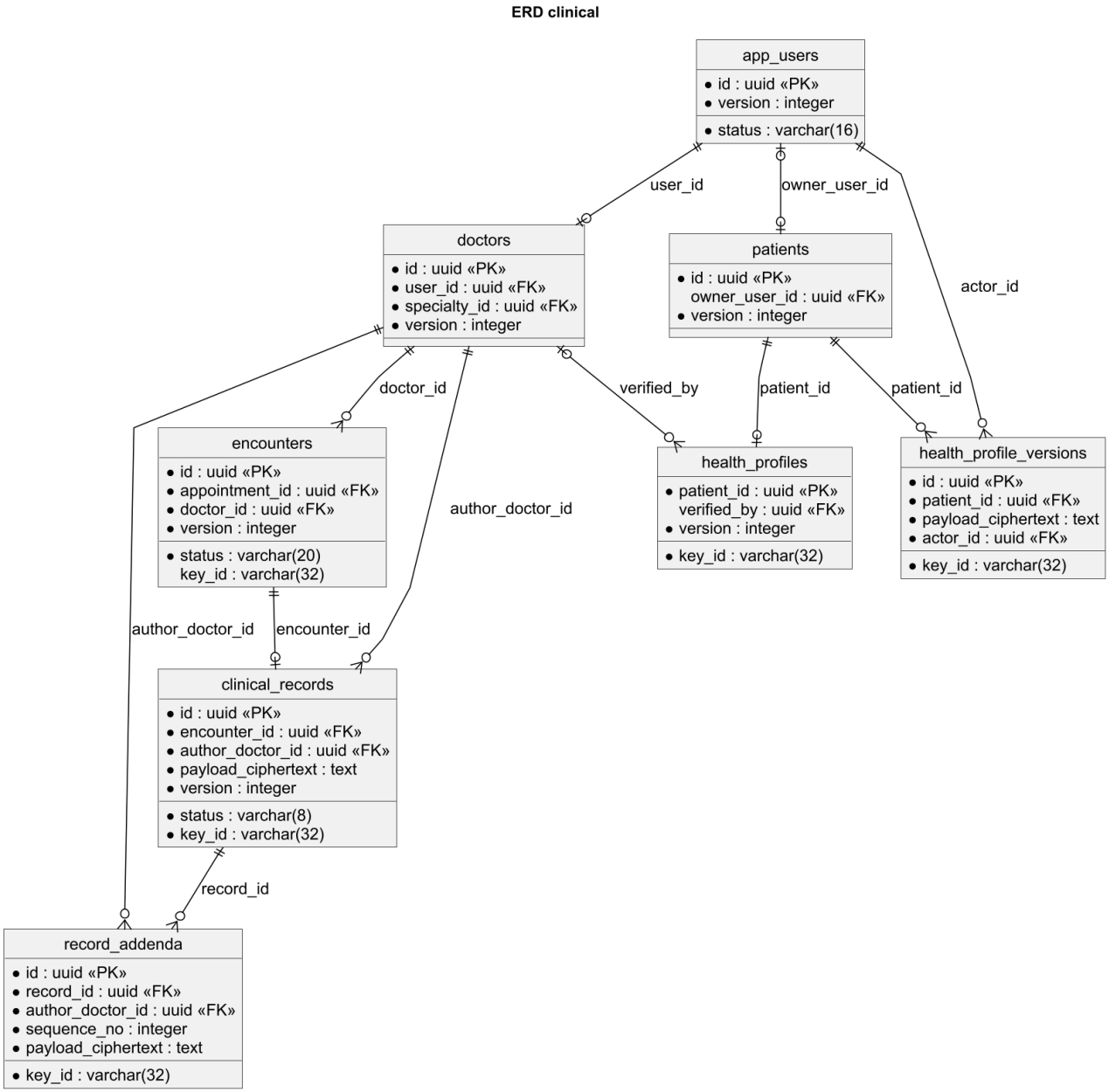
Hình 6 ERD scheduling ERD-SCHEDULING



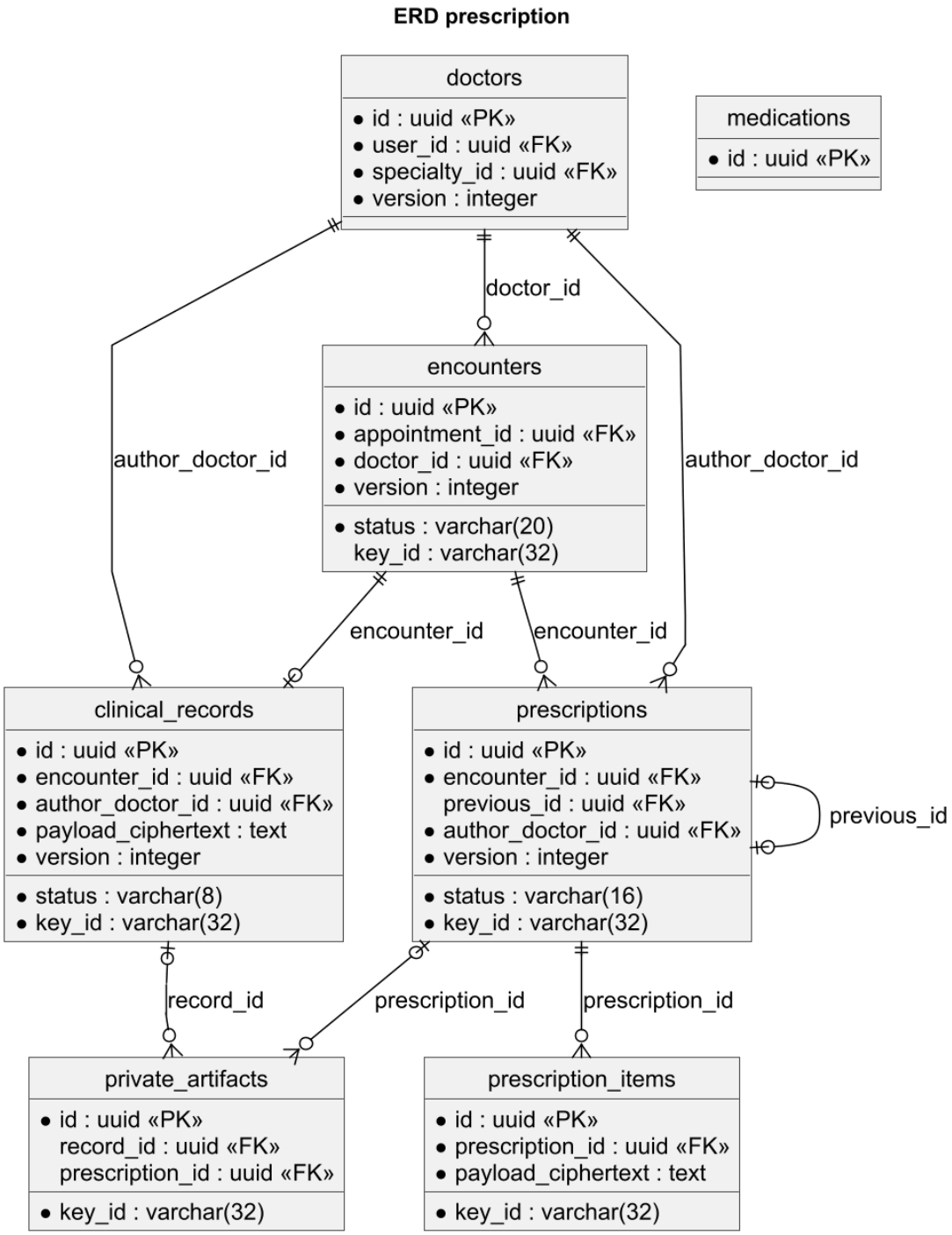
Hình 7 ERD appointment ERD-APPOINTMENT



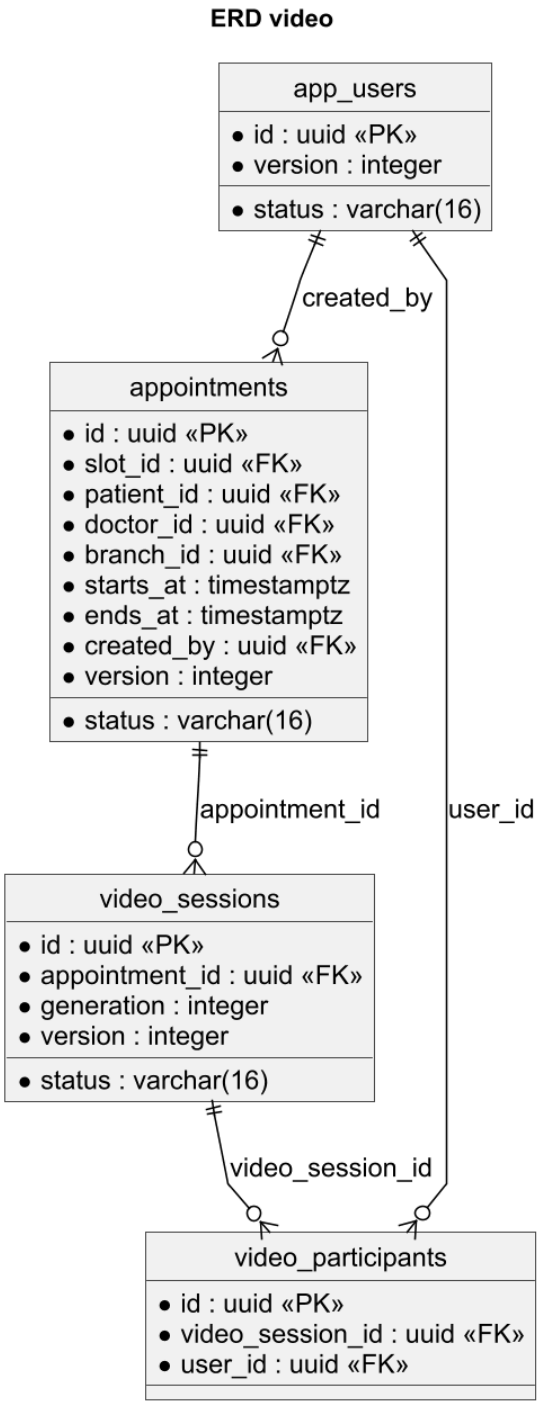
Hình 8 ERD clinical ERD-CLINICAL



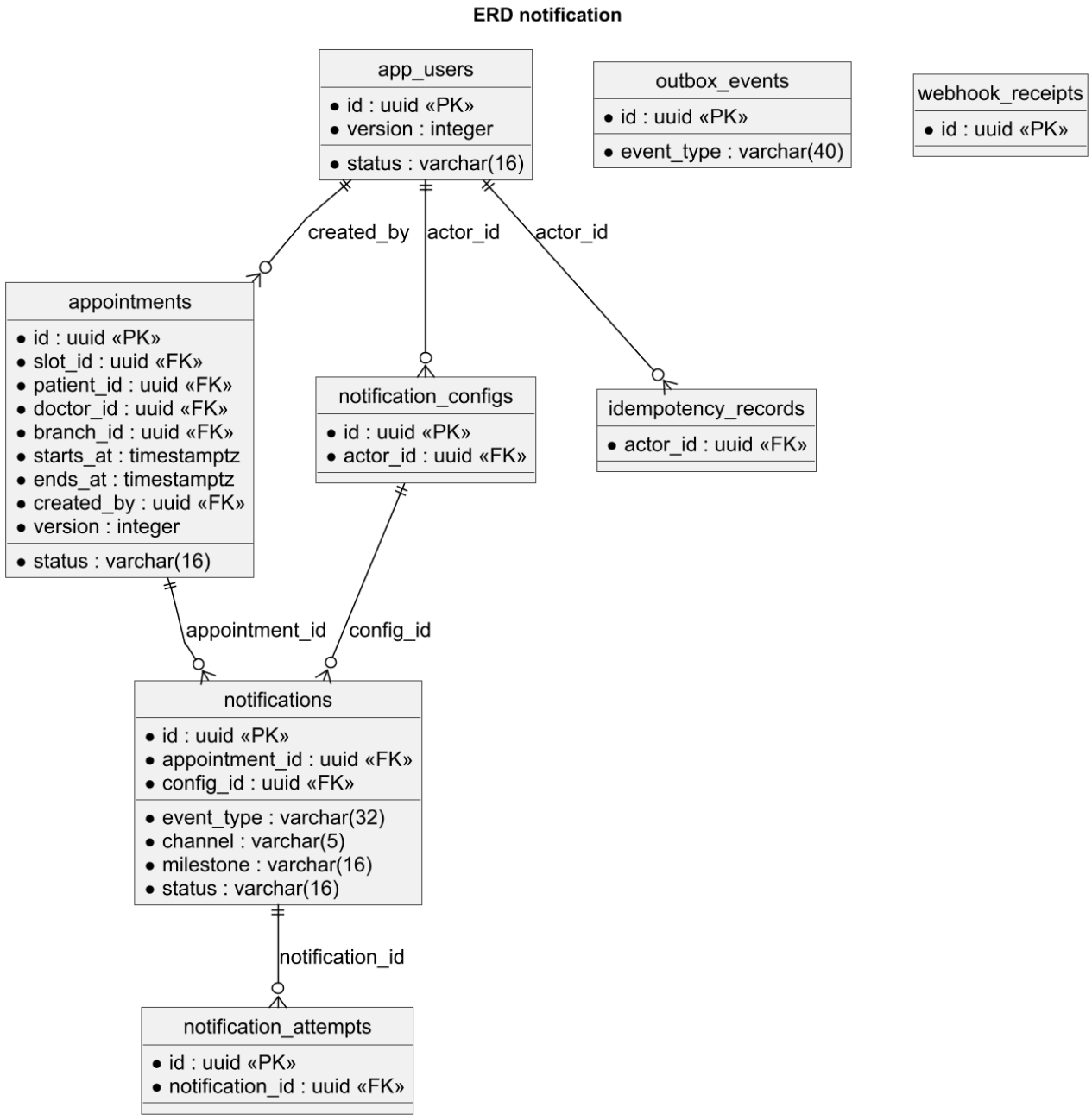
Hình 9 ERD prescription ERD-PRESCRIPTION



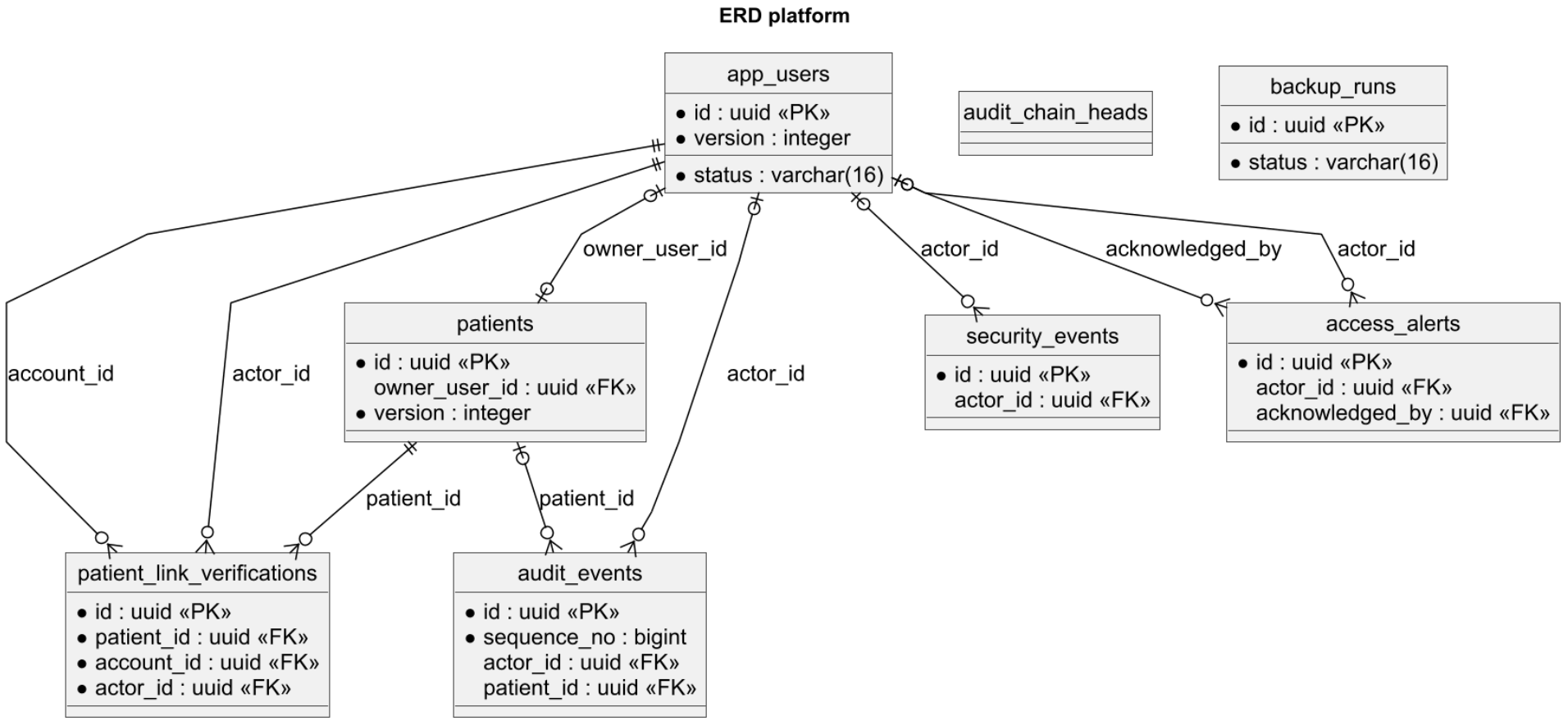
Hình 10 ERD video ERD-VIDEO



Hình 11 ERD notification ERD-NOTIFICATION



Hình 12 ERD platform ERD-PLATFORM



5.2 Schema và ràng buộc

app_users

Định danh và vai trò hiện hành. id uuid, email varchar(254), password_hash text, role varchar(16), status varchar(16), verified_at timestamptz, authz_version integer, reactivated_until timestamptz, version integer, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); email: NOT NULL UNIQUE; role: NOT NULL CHECK(role IN ('PATIENT','DOCTOR','RECEPTION','ADMIN')); status: NOT NULL DEFAULT 'PENDING' CHECK(status IN ('PENDING','ACTIVE','INACTIVE')); authz_version: NOT NULL DEFAULT 1 CHECK(authz_version>0); version: NOT NULL DEFAULT 1 CHECK (version>0)

branches

Chi nhánh một tổ chức. id uuid, code varchar(20), name varchar(150), address varchar(300), opening_hours jsonb, accepting_booking boolean, active boolean, version integer, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); code: NOT NULL UNIQUE; version: NOT NULL DEFAULT 1 CHECK (version>0)

user_branches

Phạm vi staff tại chi nhánh. user_id uuid, branch_id uuid.

Toàn vẹn user_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT; branch_id: NOT NULL REFERENCES branches(id) ON DELETE RESTRICT; PRIMARY KEY(user_id, branch_id)

specialties

Danh mục chuyên khoa. id uuid, code varchar(20), name varchar(150), active boolean, version integer.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); code: NOT NULL UNIQUE; version: NOT NULL DEFAULT 1 CHECK (version>0)

doctors

Bác sĩ và chuyên khoa chính. id uuid, user_id uuid, specialty_id uuid, public_bio varchar(1000), accepting_booking boolean, active boolean, version integer.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); user_id: NOT NULL UNIQUE REFERENCES app_users(id) ON DELETE RESTRICT; specialty_id: NOT NULL REFERENCES specialties(id) ON DELETE RESTRICT; version: NOT NULL DEFAULT 1 CHECK (version>0)

doctor_branches

Nơi bác sĩ làm việc. doctor_id uuid, branch_id uuid.

Toàn vẹn doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; branch_id: NOT NULL REFERENCES branches(id) ON DELETE RESTRICT; PRIMARY KEY(doctor_id, branch_id)

patients

Hồ sơ hành chính toàn tổ chức. id uuid, display_code varchar(24), owner_user_id uuid, full_name varchar(150), dob date, phone varchar(20), email varchar(254), active boolean, version integer, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); display_code: NOT NULL UNIQUE; owner_user_id: UNIQUE REFERENCES app_users(id) ON DELETE RESTRICT; full_name: NOT NULL CHECK(length(trim(full_name))>0); version: NOT NULL DEFAULT 1 CHECK (version>0)

patient_link_verifications

Bằng chứng xác minh liên kết. id uuid, patient_id uuid, account_id uuid, actor_id uuid, proof_digest varchar(128), created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); patient_id: NOT NULL REFERENCES patients(id) ON DELETE RESTRICT; account_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT; actor_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT

health_profiles

Hai phần sức khỏe và nguồn riêng biệt. patient_id uuid, self_ciphertext text, verified_ciphertext text, key_id varchar(32), verified_by uuid, verified_at timestamptz, version integer.

Toàn vẹn patient_id: PRIMARY KEY REFERENCES patients(id) ON DELETE RESTRICT; verified_by: REFERENCES doctors(id) ON DELETE RESTRICT; version: NOT NULL DEFAULT 1 CHECK (version>0)

health_profile_versions

Lịch sử sức khỏe bất biến. id uuid, patient_id uuid, aggregate_version integer, source varchar(16), payload_ciphertext text, key_id varchar(32), actor_id uuid, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); patient_id: NOT NULL REFERENCES patients(id) ON DELETE RESTRICT; aggregate_version: NOT NULL CHECK(aggregate_version>0); source: NOT NULL CHECK(source IN ('SELF','DOCTOR')); actor_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT; UNIQUE(patient_id, aggregate_version)

work_shifts

Ca làm đã khai báo. id uuid, doctor_id uuid, branch_id uuid, mode varchar(6), starts_at timestamptz, ends_at timestamptz, breaks jsonb, status varchar(16), version integer.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; branch_id: NOT NULL REFERENCES branches(id) ON DELETE RESTRICT; mode: NOT NULL CHECK(mode IN ('DIRECT','VIDEO')); status: NOT NULL CHECK(status IN ('DRAFT','PUBLISHED','STOPPED')); version: NOT NULL DEFAULT 1 CHECK (version>0); CHECK(starts_at<ends_at); EXCLUDE USING gist(doctor_id WITH =, tstzrange(starts_at, ends_at,'[)') WITH &&) WHERE (status IN ('PUBLISHED','STOPPED'))

slots

Slot thời gian bất biến khi được tham chiếu. id uuid, shift_id uuid, starts_at timestamptz, ends_at timestamptz, bookable boolean.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); shift_id: NOT NULL REFERENCES work_shifts(id) ON DELETE RESTRICT; CHECK(starts_at<ends_at); UNIQUE(shift_id, starts_at)

appointments

Lịch hiện hành và snapshot lịch. id uuid, slot_id uuid, patient_id uuid, doctor_id uuid, branch_id uuid, mode varchar(6), starts_at timestamptz, ends_at timestamptz, status varchar(16), coordination_status varchar(16), reason_code varchar(40), created_by uuid, version integer, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); slot_id: NOT NULL REFERENCES slots(id) ON DELETE RESTRICT; patient_id: NOT NULL REFERENCES patients(id) ON DELETE RESTRICT; doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; branch_id: NOT NULL REFERENCES branches(id) ON DELETE RESTRICT; mode: NOT NULL CHECK(mode IN ('DIRECT','VIDEO')); status: NOT NULL CHECK(status IN ('CONFIRMED','CHECKED_IN','IN_PROGRESS','COMPLETED','CANCELLED','NO_SHOW','ABORTED')); coordination_status: NOT NULL DEFAULT 'NONE' CHECK(coordination_status IN ('NONE','UNRESOLVED','RESOLVED')); created_by: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT; version: NOT NULL DEFAULT 1 CHECK (version>0); CHECK(starts_at<ends_at); EXCLUDE USING gist(doctor_id WITH =, tstzrange(starts_at, ends_at,'[)') WITH &&) WHERE(status IN ('CONFIRMED','CHECKED_IN','IN_PROGRESS')); EXCLUDE USING gist(patient_id WITH =, tstzrange(starts_at, ends_at,'[)') WITH &&) WHERE(status IN ('CONFIRMED','CHECKED_IN','IN_PROGRESS'))

appointment_history

Lịch sử version bất biến. id uuid, appointment_id uuid, aggregate_version integer, before_slot_id uuid, after_slot_id uuid, event varchar(32), status_after varchar(16), reason varchar(500), actor_id uuid, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); appointment_id: NOT NULL REFERENCES appointments(id) ON DELETE RESTRICT; aggregate_version: NOT NULL CHECK(aggregate_version>0); before_slot_id: REFERENCES slots(id) ON DELETE RESTRICT; after_slot_id: NOT NULL REFERENCES slots(id) ON DELETE RESTRICT; actor_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT; UNIQUE(appointment_id, aggregate_version)

care_assignments

Quyền theo quan hệ điều trị. id uuid, appointment_id uuid, patient_id uuid, doctor_id uuid, read_from timestamptz, status varchar(16), revoked_at timestamptz, version integer.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); appointment_id: NOT NULL UNIQUE REFERENCES appointments(id) ON DELETE RESTRICT; patient_id: NOT NULL REFERENCES patients(id) ON DELETE RESTRICT; doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; status: NOT NULL CHECK(status IN ('SCHEDULED','IN_CARE','HISTORICAL','REVOKED')); version: NOT NULL DEFAULT 1 CHECK (version>0)

coordination_requests

Quyết định điều phối có phản hồi. id uuid, appointment_id uuid, proposed_slot_id uuid, response varchar(16), contact_channel varchar(16), actor_id uuid, reason varchar(500), created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); appointment_id: NOT NULL REFERENCES appointments(id) ON DELETE RESTRICT; proposed_slot_id: REFERENCES slots(id) ON DELETE RESTRICT; response: NOT NULL CHECK(response IN ('UNREACHED','ACCEPTED','DECLINED','CLINIC_CANCELLED')); actor_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT

encounters

Lượt khám riêng appointment. id uuid, appointment_id uuid, doctor_id uuid, status varchar(20), checked_in_at timestamptz, started_at timestamptz, ended_at timestamptz, abort_reason_ciphertext text, key_id varchar(32), version integer.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); appointment_id: NOT NULL UNIQUE REFERENCES appointments(id) ON DELETE RESTRICT; doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; status: NOT NULL CHECK(status IN ('WAITING','CHECKIN_CANCELLED','IN_PROGRESS','COMPLETED','ABORTED')); version: NOT NULL DEFAULT 1 CHECK (version>0)

clinical_records

Bản khám gốc và trạng thái. id uuid, encounter_id uuid, author_doctor_id uuid, status varchar(8), payload_ciphertext text, key_id varchar(32), validation_complete boolean, finalized_at timestamptz, version integer.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); encounter_id: NOT NULL UNIQUE REFERENCES encounters(id) ON DELETE RESTRICT; author_doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; status: NOT NULL CHECK(status IN ('DRAFT','FINAL')); version: NOT NULL DEFAULT 1 CHECK (version>0); CHECK(status<>'FINAL' OR (validation_complete AND finalized_at IS NOT NULL))

record_addenda

Bổ sung bất biến không ghi đè gốc. id uuid, record_id uuid, author_doctor_id uuid, sequence_no integer, payload_ciphertext text, key_id varchar(32), created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); record_id: NOT NULL REFERENCES clinical_records(id) ON DELETE RESTRICT; author_doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; sequence_no: NOT NULL CHECK(sequence_no>0); UNIQUE(record_id, sequence_no)

medications

Danh mục thuốc phục vụ demo. id uuid, code varchar(30), name varchar(150), strength varchar(60), allergen_group varchar(60), active boolean.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); code: NOT NULL UNIQUE

prescriptions

Chuỗi phiên bản đơn. id uuid, encounter_id uuid, previous_id uuid, author_doctor_id uuid, rx_code varchar(24), revision_no integer, status varchar(16), reason_ciphertext text, key_id varchar(32), validation_complete boolean, issued_at timestamptz, version integer.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); encounter_id: NOT NULL REFERENCES encounters(id) ON DELETE RESTRICT; previous_id: UNIQUE REFERENCES prescriptions(id) ON DELETE RESTRICT; author_doctor_id: NOT NULL REFERENCES doctors(id) ON DELETE RESTRICT; rx_code: NOT NULL UNIQUE; revision_no: NOT NULL CHECK(revision_no>0); status: NOT NULL CHECK(status IN ('DRAFT','ISSUED','SUPERSEDED','DISCARDED')); version: NOT NULL DEFAULT 1 CHECK (version>0); UNIQUE(encounter_id, revision_no); CHECK(status NOT IN ('ISSUED','SUPERSEDED') OR (validation_complete AND issued_at IS NOT NULL))

prescription_items

Dòng đơn chuẩn hóa, nội dung mã hóa. id uuid, prescription_id uuid, position integer, payload_ciphertext text, key_id varchar(32), validation_complete boolean.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); prescription_id: NOT NULL REFERENCES prescriptions(id) ON DELETE RESTRICT; position: NOT NULL CHECK(position BETWEEN 1 AND 30); UNIQUE(prescription_id, position)

video_sessions

Phiên video theo generation. id uuid, appointment_id uuid, appointment_version integer, generation integer, provider_room_name varchar(100), status varchar(16), disconnected_since timestamptz, access_closed boolean, cleanup_pending boolean, provider_closed_at timestamptz, version integer, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); appointment_id: NOT NULL REFERENCES appointments(id) ON DELETE RESTRICT; generation: NOT NULL CHECK(generation>0); provider_room_name: NOT NULL UNIQUE; status: NOT NULL CHECK(status IN ('CREATED','WAITING','ACTIVE','DISCONNECTED','ENDED','FAILED')); version: NOT NULL DEFAULT 1 CHECK (version>0); UNIQUE(appointment_id, generation)

video_participants

Hai participant theo vai trò ca. id uuid, video_session_id uuid, user_id uuid, role varchar(8), consented_at timestamptz, connected boolean, last_event_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); video_session_id: NOT NULL REFERENCES video_sessions(id) ON DELETE RESTRICT; user_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT; role: NOT NULL CHECK(role IN ('PATIENT','DOCTOR')); UNIQUE(video_session_id, role); UNIQUE(video_session_id, user_id)

outbox_events

Sự kiện đáng tin cậy sau commit. id uuid, aggregate_id uuid, aggregate_version integer, event_type varchar(40), payload jsonb, published_at timestamptz, lease_until timestamptz, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); UNIQUE(aggregate_id, aggregate_version, event_type)

notification_configs

Mẫu có version. id uuid, version_no integer, effective_at timestamptz, templates jsonb, reminder_minutes integer[], actor_id uuid.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); version_no: NOT NULL UNIQUE; actor_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT

notifications

Logical notification theo version. id uuid, appointment_id uuid, appointment_version integer, config_id uuid, event_type varchar(32), channel varchar(5), milestone varchar(16), status varchar(16), due_at timestamptz, authorized_at timestamptz, lease_until timestamptz, provider_message_id varchar(200), created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); appointment_id: NOT NULL REFERENCES appointments(id) ON DELETE RESTRICT; config_id: NOT NULL REFERENCES notification_configs(id) ON DELETE RESTRICT; channel: NOT NULL CHECK(channel IN ('EMAIL','SMS')); status: NOT NULL CHECK(status IN ('QUEUED','PROCESSING','ACCEPTED','DELIVERED','FAILED','UNKNOWN','SKIPPED','SIMULATED')); UNIQUE(appointment_id, appointment_version, event_type, channel, milestone)

notification_attempts

Mỗi lần gửi có bằng chứng. id uuid, notification_id uuid, attempt_no integer, result varchar(16), error_code varchar(60), provider_message_id varchar(200), created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); notification_id: NOT NULL REFERENCES notifications(id) ON DELETE RESTRICT; attempt_no: NOT NULL CHECK(attempt_no BETWEEN 1 AND 3); result: NOT NULL CHECK(result IN ('ACCEPTED','FAILED','UNKNOWN','SIMULATED')); UNIQUE(notification_id, attempt_no)

webhook_receipts

Dedup callback đã xác thực. id uuid, provider varchar(12), event_id varchar(200), payload_digest varchar(128), received_at timestamptz, processed_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); provider: NOT NULL CHECK(provider IN ('MAILGUN','DAILY')); UNIQUE(provider, event_id)

idempotency_records

Kết quả command chống lặp. actor_id uuid, operation varchar(80), key varchar(100), request_hash varchar(128), resource_id uuid, response_code integer, expires_at timestamptz.

Toàn vẹn actor_id: NOT NULL REFERENCES app_users(id) ON DELETE RESTRICT; PRIMARY KEY(actor_id, operation, key)

audit_chain_heads

Điểm đầu chuỗi từng ngày. partition_date date, last_sequence bigint, last_hash varchar(128).

Toàn vẹn partition_date: PRIMARY KEY

audit_events

PHI audit append only. id uuid, partition_date date, sequence_no bigint, actor_id uuid, role_snapshot varchar(16), patient_id uuid, resource_type varchar(32), resource_id uuid, action varchar(32), outcome varchar(12), request_id uuid, source_digest varchar(128), previous_hash varchar(128), event_hash varchar(128), created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); actor_id: REFERENCES app_users(id) ON DELETE RESTRICT; patient_id: REFERENCES patients(id) ON DELETE RESTRICT; outcome: NOT NULL CHECK(outcome IN ('ALLOW','DENY','ERROR')); UNIQUE(partition_date, sequence_no)

security_events

Audit cấu hình và log bảo mật sạch. id uuid, actor_id uuid, action varchar(64), outcome varchar(12), request_id uuid, metadata jsonb, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); actor_id: REFERENCES app_users(id) ON DELETE RESTRICT

access_alerts

Cảnh báo metadata. id uuid, actor_id uuid, rule_code varchar(32), window_start timestamptz, acknowledged_by uuid, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); actor_id: REFERENCES app_users(id) ON DELETE RESTRICT; acknowledged_by: REFERENCES app_users(id) ON DELETE RESTRICT; UNIQUE(actor_id, rule_code, window_start)

private_artifacts

Tệp kết quả riêng tư có mã hóa. id uuid, record_id uuid, prescription_id uuid, storage_key varchar(300), key_id varchar(32), content_digest varchar(128), source_version integer, expires_at timestamptz, created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); record_id: REFERENCES clinical_records(id) ON DELETE RESTRICT; prescription_id: REFERENCES prescriptions(id) ON DELETE RESTRICT; storage_key: NOT NULL UNIQUE; CHECK((record_id IS NOT NULL)::integer+ (prescription_id IS NOT NULL)::integer=1)

backup_runs

Bằng chứng hạ tầng không chứa dữ liệu. id uuid, status varchar(16), manifest_digest varchar(128), source_timestamp timestamptz, completed_at timestamptz, error_code varchar(64), created_at timestamptz.

Toàn vẹn id: PRIMARY KEY DEFAULT gen_random_uuid(); status: NOT NULL CHECK(status IN ('STARTED','VERIFIED','FAILED','RESTORE_VALIDATED'))

Data_Dictionary.md chứa ý nghĩa từng cột và miền logic bên trong ciphertext. 001_domain_schema.sql chứa PK/FK/CHECK/exclusion/index/guards; 002_runtime_permissions.sql cấp quyền runtime riêng. Integrity_and_Migration.md quy định thứ tự framework migrations, key ring và expand/contract. Những file này là thành phần chính thức của thiết kế.

5.3 Index và khóa

Unique partial index one_slot_occupancy cho CONFIRMED/CHECKED_IN/IN_PROGRESS; exclusions doctor và patient trên tstzrange [start, end). one_active_encounter chặn hai lượt đang khám; one_current_prescription chặn hai bản ISSUED; one_open_video chặn hai room chưa terminal. Index branch/day/status phục vụ vận hành; patient/time phục vụ lịch sử; doctor/status/read_from phục vụ quyền; due_at phục vụ worker; audit(patient, time) và audit(actor, time) phục vụ tra cứu.

Thứ tự khóa: các app_users liên quan theo UUID, FOR SHARE cho actor để giữ quyền đến commit; doctor UUID tăng; patient UUID tăng; appointment; encounter; record/prescription; audit_chain_heads ngày. Revoke dùng khóa exclusive trên user nên thứ tự commit xác định thao tác nào có hiệu lực trước. Service không giữ khóa khi gọi provider/render PDF. Khi DB báo23P01/23505, map thành409 nghiệp vụ; deadlock40P01/serialization40001 retry tối đa hai lần với cùng key, không retry provider side effect.

6 Hợp đồng API

openapi.yaml là OpenAPI 3.1.1 đầy đủ với schema, examples, operationId, auth, phân trang, request/response, mã lỗi và x-fr/x-use-cases/x-entities. Domain trong servers là giá trị minh họa hợp đồng; domain triển khai được gắn ở runtime. API nghiệp vụ có prefix /api/v1; OAuth authorize/token/callback là route identity tại root origin. Thư mục source không chứa secret hoặc tài khoản provider.

GET trả theo phạm vi và no-store với dữ liệu người dùng; list dùng page≥1, page_size1..100 mặc định20, từ/toUTC và thứ tự ổn định starts_at/id hoặc created_at/id. Validation422 chỉ tên trường và errorcode, không echo nội dungPHI. GET ngoài scope 404 đồng nhất không tồn tại; actor role bị cấm403; thiếu xác thực401. Mutation dùng expected_version, và Idempotency-Key bắt buộc cho command; replay cache chỉ resource_id/response_code, đọc lại quyền và trả bản được phép, không cachePHI plaintext.

Bảng 3 Danh mục operationId và quyền

OperationId và đường dẫn	Quyền	Yêu cầu
register POST /auth/register	PUBLIC	FR-01.1
verifyEmail POST /auth/verify	PUBLIC	FR-01.1
resendVerification POST /auth/resend-verification	PUBLIC	FR-01.1
logout POST /auth/logout	AUTH	FR-01.7
changePassword POST /auth/change-password	AUTH	FR-01.8
requestPasswordReset POST /auth/reset-request	PUBLIC	FR-01.3
resetPassword POST /auth/reset	PUBLIC	FR-01.3
listStaff GET /admin/users	ADMIN	FR-01.4
createStaff POST /admin/users	ADMIN	FR-01.4
updateStaff PATCH /admin/users/{id}	ADMIN	FR-01.4, FR-01.5
listBranches GET /branches	PUBLIC	FR-03.1
createBranch POST /admin/branches	ADMIN	FR-03.1
updateBranch PATCH /admin/branches/{id}	ADMIN	FR-03.1
listSpecialties GET /specialties	PUBLIC	FR-03.1
createSpecialty POST /admin/specialties	ADMIN	FR-03.1
updateSpecialty PATCH /admin/specialties/{id}	ADMIN	FR-03.1
listDoctors GET /doctors	PUBLIC	FR-03.1
createDoctor POST /admin/doctors	ADMIN	FR-03.1
updateDoctor PATCH /admin/doctors/{id}	ADMIN	FR-03.1
searchPatients GET /patients	RECEPTION	FR-02.3
createPatient POST /patients	PATIENT, RECEPTION	FR-02.1
getPatient GET /patients/{id}	PATIENT, DOCTOR, RECEPTION	FR-02.1

OperationId và đường dẫn	Quyền	Yêu cầu
updatePatient PATCH /patients/{id}	PATIENT, RECEPTION	FR-02.1
deactivatePatient POST /patients/{id}/deactivate	PATIENT, RECEPTION	FR-02.6
requestLinkVerification POST /patients/{id}/link-verifications	RECEPTION	FR-02.5
linkPatientAccount POST /patients/{id}/link-account	RECEPTION	FR-02.5
getHealthProfile GET /patients/{id}/health	PATIENT, DOCTOR	FR-02.4, FR-09.1
updateSelfHealth PUT /patients/{id}/health/self	PATIENT	FR-02.2
verifyHealth PUT /patients/{id}/health/verified	DOCTOR	FR-02.7
listPatientRecords GET /patients/{id}/records	PATIENT, DOCTOR	FR-02.4, FR-09.1
listShifts GET /work-shifts	DOCTOR, RECEPTION, ADMIN	FR-03.5
createShift POST /work-shifts	DOCTOR, ADMIN	FR-03.2, FR-03.6
updateShift PATCH /work-shifts/{id}	DOCTOR, ADMIN	FR-03.2, FR-03.6
stopShift POST /work-shifts/{id}/stop	DOCTOR, ADMIN	FR-03.3
listSlots GET /slots	PUBLIC	FR-03.4, FR-04.1
listAppointments GET /appointments	PATIENT, DOCTOR, RECEPTION	FR-04.3, FR-03.5
bookAppointment POST /appointments	PATIENT, RECEPTION	FR-04.2
getAppointment GET /appointments/{id}	PATIENT, DOCTOR, RECEPTION	FR-04.3
getAppointmentHistory GET /appointments/{id}/history	PATIENT, DOCTOR, RECEPTION	FR-04.3
rescheduleAppointment POST /appointments/{id}/reschedule	PATIENT, RECEPTION	FR-04.4
cancelAppointment POST /appointments/{id}/cancel	PATIENT, RECEPTION	FR-04.5
createCoordination POST /coordination-requests	RECEPTION	FR-04.6, FR-03.3
checkInDirect POST /appointments/{id}/check-in	RECEPTION	FR-05.1
markNoShow POST /appointments/{id}/no-show	DOCTOR, RECEPTION	FR-05.4
listEncounters GET /encounters	DOCTOR, RECEPTION	FR-05.6
getEncounter GET /encounters/{id}	DOCTOR, RECEPTION	FR-05.6
cancelCheckIn POST /encounters/{id}/cancel-check-in	DOCTOR, RECEPTION	FR-05.7
startEncounter POST /encounters/{id}/start	DOCTOR	FR-05.3
abortEncounter POST /encounters/{id}/abort	DOCTOR	FR-05.5
getRecordDraft GET /encounters/{id}/record-draft	DOCTOR	FR-06.1, FR-09.1
saveRecordDraft PUT /encounters/{id}/record-draft	DOCTOR	FR-06.1
savePrescriptionDraft PUT /encounters/{id}/prescription-draft	DOCTOR	FR-06.3, FR-06.4

OperationId và đường dẫn	Quyền	Yêu cầu
listMedications GET /medications	DOCTOR	FR-06.3
finalizeEncounter POST /encounters/{id}/finalize	DOCTOR	FR-06.2, FR-06.3, FR-06.4
getClinicalRecord GET /records/{id}	PATIENT, DOCTOR	FR-06.6, FR-09.1
listAddenda GET /records/{id}/addenda	PATIENT, DOCTOR	FR-06.6
createAddendum POST /records/{id}/addenda	DOCTOR	FR-06.5
downloadRecord GET /records/{id}/download	PATIENT, DOCTOR	FR-06.8
getPrescription GET /prescriptions/{id}	PATIENT, DOCTOR	FR-06.6
revisePrescription POST /prescriptions/{id}/revisions	DOCTOR	FR-06.7, FR-06.4
downloadPrescription GET /prescriptions/{id}/download	PATIENT, DOCTOR	FR-06.8
joinVideo POST /appointments/{id}/video-token	PATIENT, DOCTOR	FR-07.1, FR-07.2, FR-07.4, FR-07.5
getVideoState GET /appointments/{id}/video	PATIENT, DOCTOR	FR-07.4, FR-07.5
videoClientEvent POST /appointments/{id}/video-events	PATIENT, DOCTOR	FR-07.4
acceptVideoPatient POST /appointments/{id}/video-accept	DOCTOR	FR-05.8, FR-07.3
endVideo POST /appointments/{id}/video-end	DOCTOR	FR-07.7
listNotifications GET /notifications	PATIENT, DOCTOR, RECEPTION, ADMIN	FR-08.4
reconcileNotification POST /notifications/{id}/reconcile	RECEPTION	FR-08.3
getNotificationConfig GET /notification-config	ADMIN	FR-08.5
updateNotificationConfig PUT /notification-config	ADMIN	FR-08.5
mailgunWebhook POST /webhooks/mailgun	MAILGUN	FR-08.6
dailyWebhook POST /webhooks/daily	DAILY	FR-07.4, FR-07.5
listAuditEvents GET /audit-events	ADMIN	FR-09.2
exportAudit POST /audit-export	ADMIN	FR-09.3
listAccessAlerts GET /access-alerts	ADMIN	FR-09.4
acknowledgeAccessAlert POST /access-alerts/{id}/acknowledge	ADMIN	FR-09.4
healthLive GET /health/live	PUBLIC	FR-09.6
oauthAuthorize GET /oauth/authorize	PUBLIC	FR-01.2
oauthToken POST /oauth/token	OAUTHCLIENT	FR-01.2, FR-01.6
oauthRevoke POST /oauth/revoke	OAUTHCLIENT	FR-01.6

6.1 Luồng OAuth2 và phiên

Khi bấm Đăng nhập, app WPF tạo state, code_verifier ngẫu nhiên và code_challenge S256, mở system browser tới OpenIddict /oauth/authorize trên HTTPS. Identity Server hiển thị trang nhập thông tin và kiểm tra ACTIVE/verified/rate limit; trả authorization code về loopback redirect URI http://127.0.0.1:<cổng_động>/callback đã đăng ký. App kiểm tra state và đổi code tại /oauth/token với verifier; app là public client, KHÔNG có client_secret. API chỉ chấp nhận Bearer token hợp lệ và kiểm tra authz_version/policy.

Access token 15 phút; refresh tối đa tám giờ theo chính sách server, rotation và revoke qua OpenIddict. Token cần lưu bền được giữ trong Windows DPAPI (ProtectedData), clear khi logout/revoke; không ghi vào Preferences, log, backup client. API dùng Bearer OAuth2 với scope clinic nhưng vẫn thực thi quyền theo chi nhánh/quan hệ bệnh nhân. PKCE không thay thế kiểm tra redirect URI, state, TLS hoặc quyền; không bật password/implicit grant.

6.2 Error taxonomy và recovery

Bảng 4 Mã lỗi chuẩn

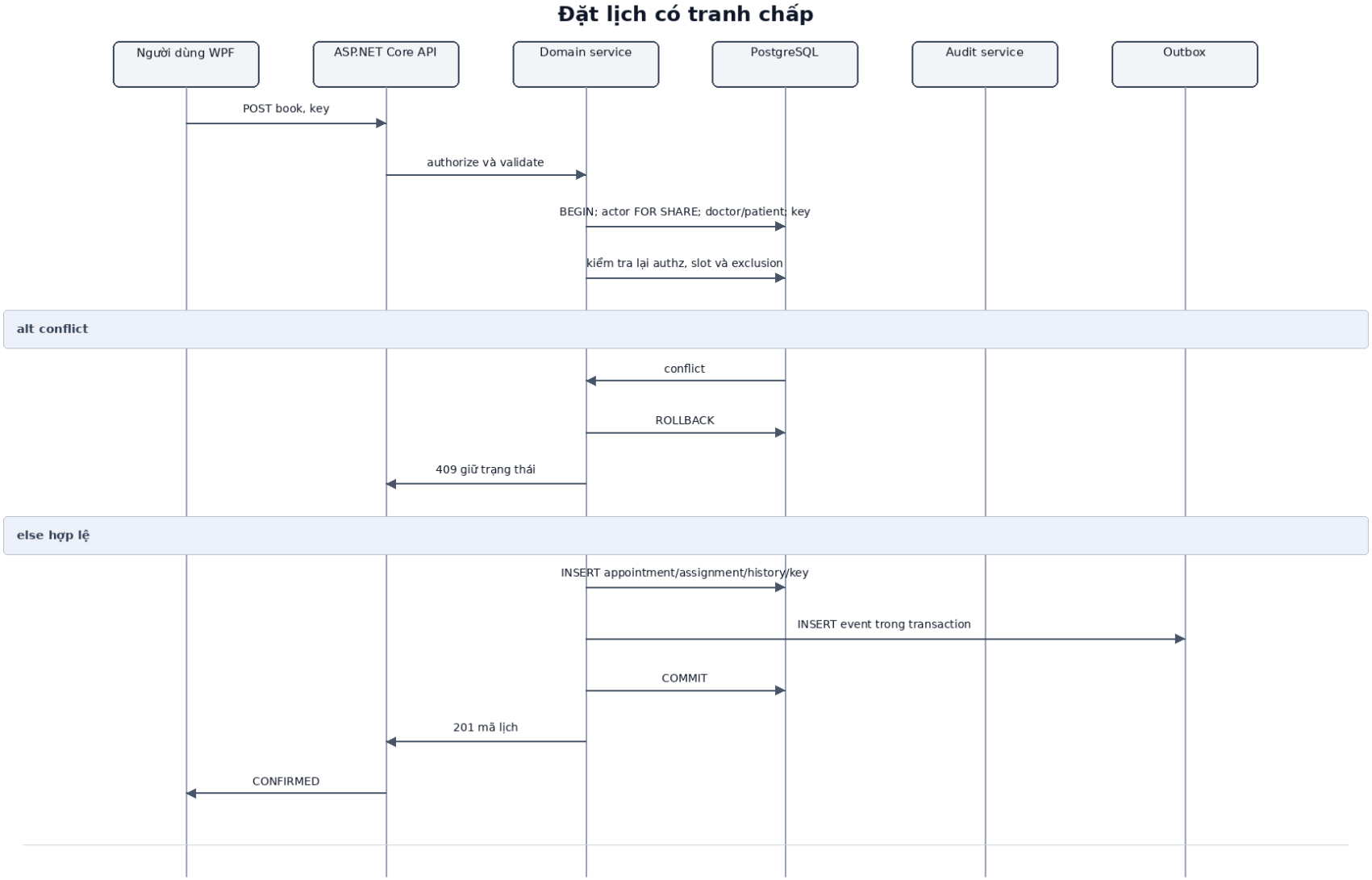
Mã và HTTP	Phát hiện	Retry và recovery
BAD_REQUEST 400	JSON/cursor sai cú pháp	Không; Không thay đổi; sửa payload
UNAUTHENTICATED 401	Token/phiên thiếu hoặc hết hiệu lực	Sau đăng nhập; Không PHI; đăng nhập lại
FORBIDDEN 403	Vai trò hoặc trạng thái tài khoản không được phép	Không; Không thay đổi; ghi denied nếu liên quan PHI
NOT_FOUND 404	ID không tồn tại hoặc tài nguyên ngoài phạm vi	Không; Phản hồi cùng dạng, không lộ tồn tại
SLOT_UNAVAILABLE 409	Slot đã bị giữ hoặc stop booking	Không mù; Chọn lại; giữ lịch cũ khi đổi
PATIENT_TIME_CONFLICT 409	Lịch patient overlap	Không; Chọn giờ khác
DOCTOR_TIME_CONFLICT 409	Doctor/shift overlap hoặc buffer	Không; Giữ ca cũ; sửa lịch
DOCTOR_BUSY 409	Đã có encounter IN_PROGRESS	Sau kết thúc ca; Giữ WAITING
STALE_VERSION 409	expected_version không hiện hành	Sau tải lại; Không last-write-wins
INVALID_STATE 409	Sự kiện không được phép từ trạng thái hiện tại	Không; Giữ trạng thái; chọn thao tác đúng
IDEMPOTENCY_CONFLICT 409	Cùng key khác payload	Key mới cho thao tác mới; Không xử lý lại
VALIDATION_ERROR 422	Trường dữ liệu hoặc quy tắc ngưỡng sai	Sau sửa; errors chỉ tên trường/mã, không echoPHI
TOO_MANY_REQUESTS 429	Giới hạn login/API	Sau Retry-After; Không khóa tài khoản vĩnh viễn
INTERNAL_ERROR 500	Lỗi nội bộ không dự kiến	Đọc lại trạng thái trước retry mutation; Log request_id sạch, rollback nếu chưa commit
AUDIT_UNAVAILABLE 503	Không ghi audit bắt buộc	Sau dịch vụ phục hồi/key cũ; Không PHI hoặc rollback mutation
PROVIDER_UNAVAILABLE 503	Video/provider không đáp ứng	Theo hạn video/attempt; Giữ lịch/nháp; cleanup_pending
DEPENDENCY_UNAVAILABLE 503	DB/storage/key thiếu	Sau phục hồi; Không plaintext/bypass; no partial state

Mỗi request có X-Request-Id UUID; lỗi5xx vào technical log sạch, không stacktrace cho client. Lỗi audit khi đọc không có byte PHI; khi ghi rollback toàn bộ. Network lostresponse cần đọc trạng thái hoặc replay key, không tự tạo command mới. Không dùng câu “thành công” khi chỉ gửi được request hoặc chưa commit.

7 Thiết kế luồng và tranh chấp

7.1 Đặt lịch

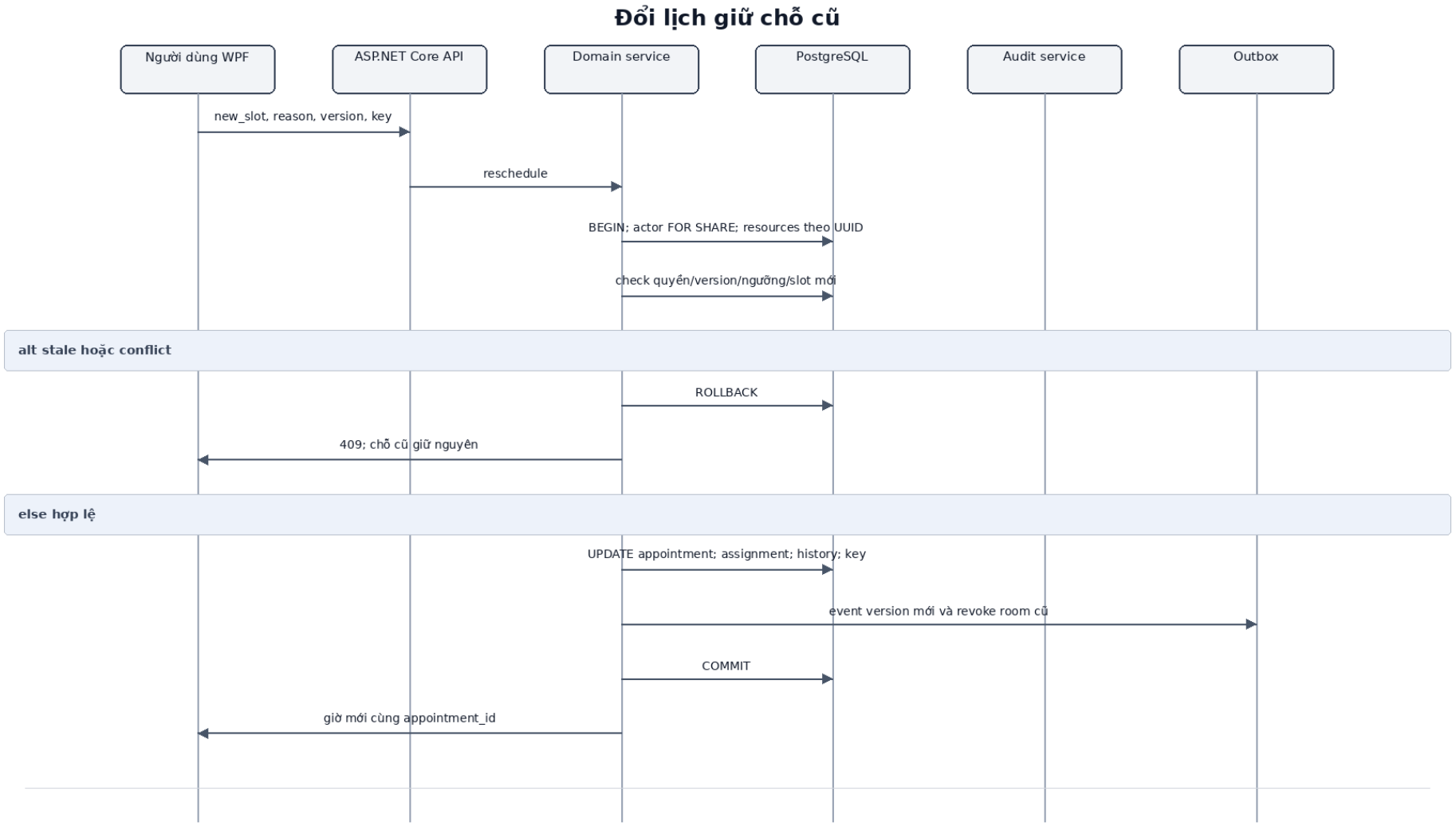
Hình 13 Đặt lịch có tranh chấp UML-SEQ-BOOK



Hình 13 biểu diễn đặt lịch có tranh chấp.

7.2 Đổi lịch

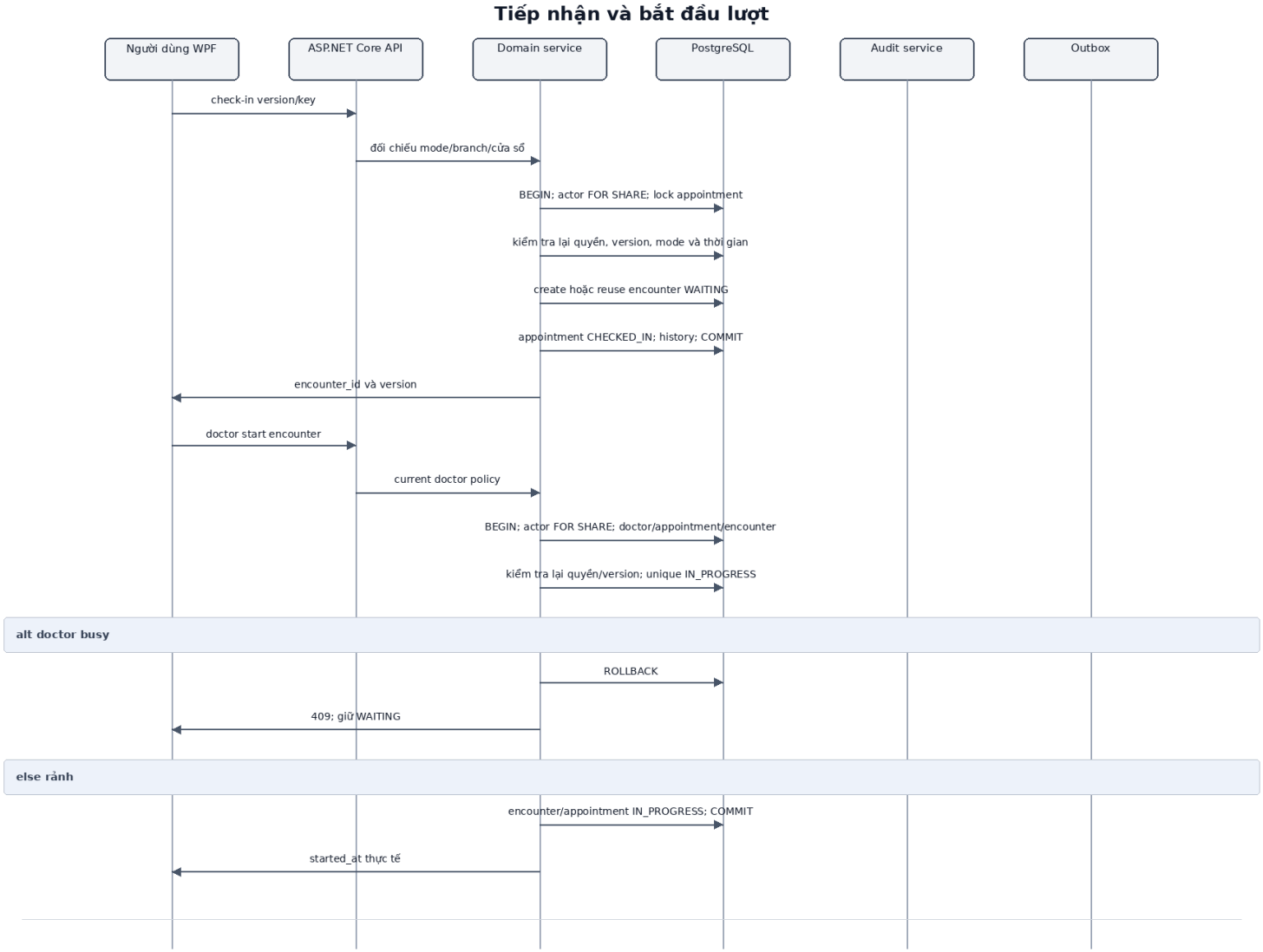
Hình 14 Đổi lịch giữ chỗ cũ UML-SEQ-RESCHEDULE



Hình 14 biểu diễn đổi lịch giữ chỗ cũ.

7.3 Tiếp nhận và bắt đầu

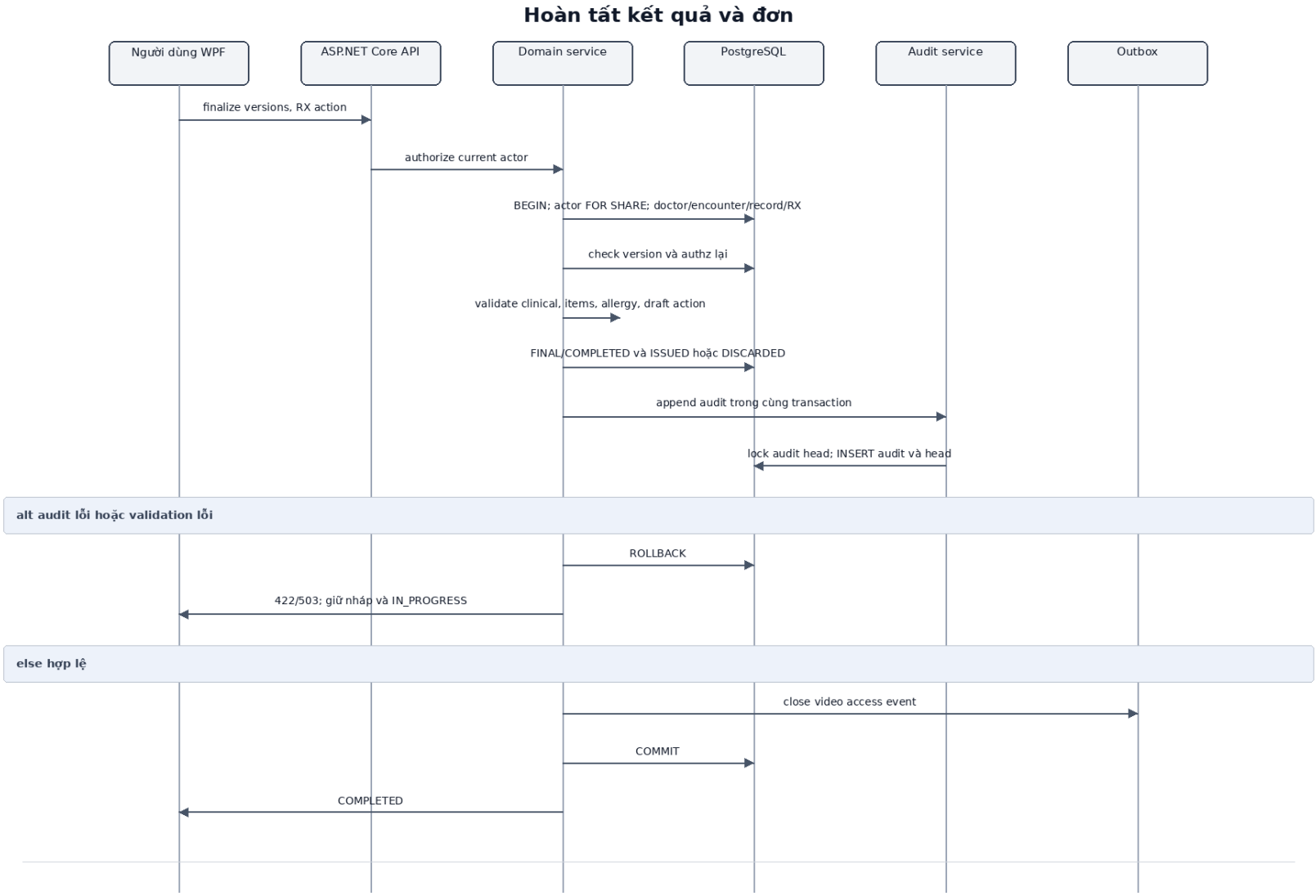
Hình 15 Tiếp nhận và bắt đầu lượt UML-SEQ-CHECKIN



Hình 15 biểu diễn tiếp nhận và bắt đầu lượt.

7.4 Hoàn tất lâm sàng

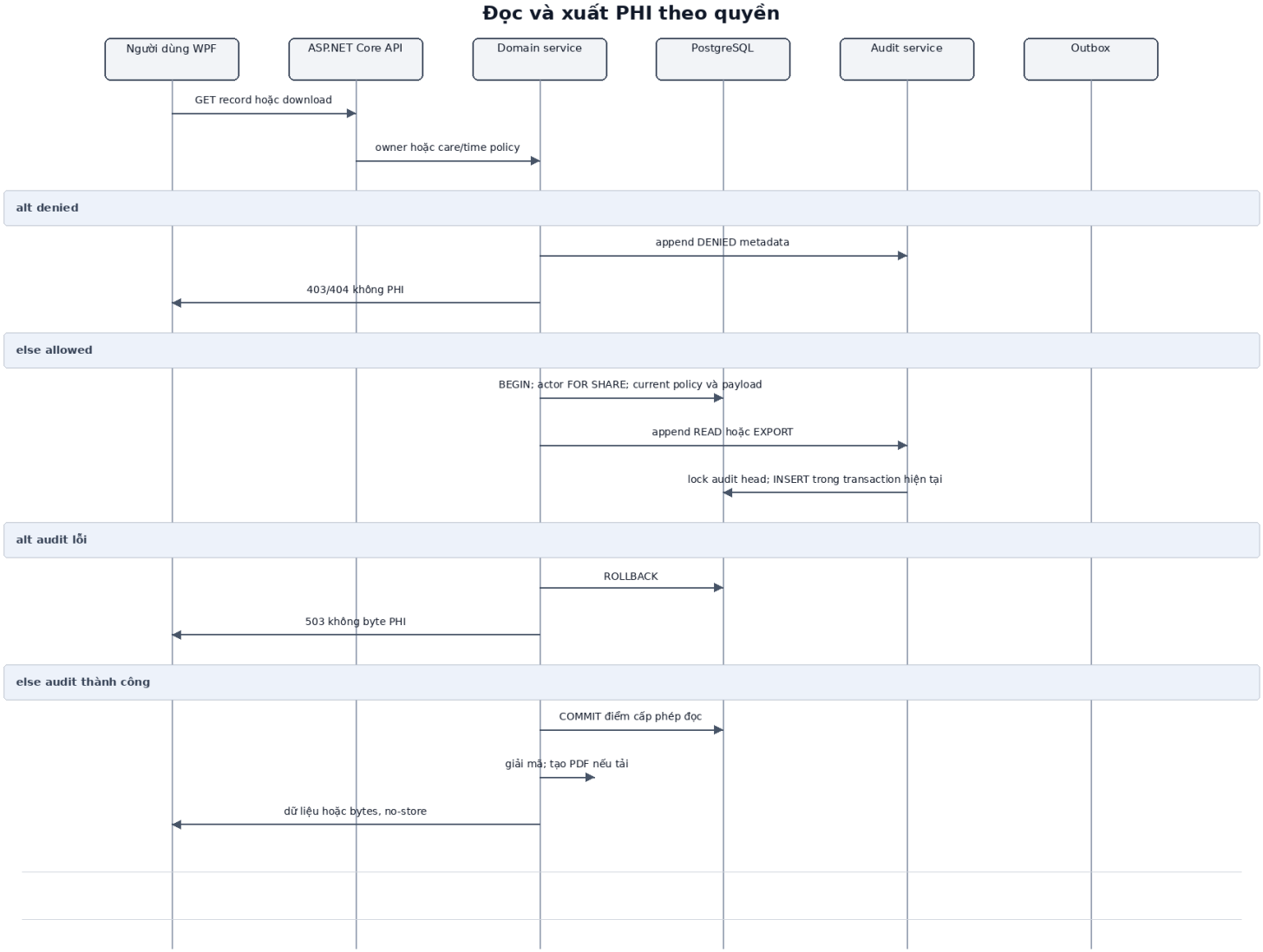
Hình 16 Hoàn tất kết quả và đơn UML-SEQ-FINALIZE



Hình 16 biểu diễn hoàn tất kết quả và đơn.

7.5 Đọc và xuất PHI

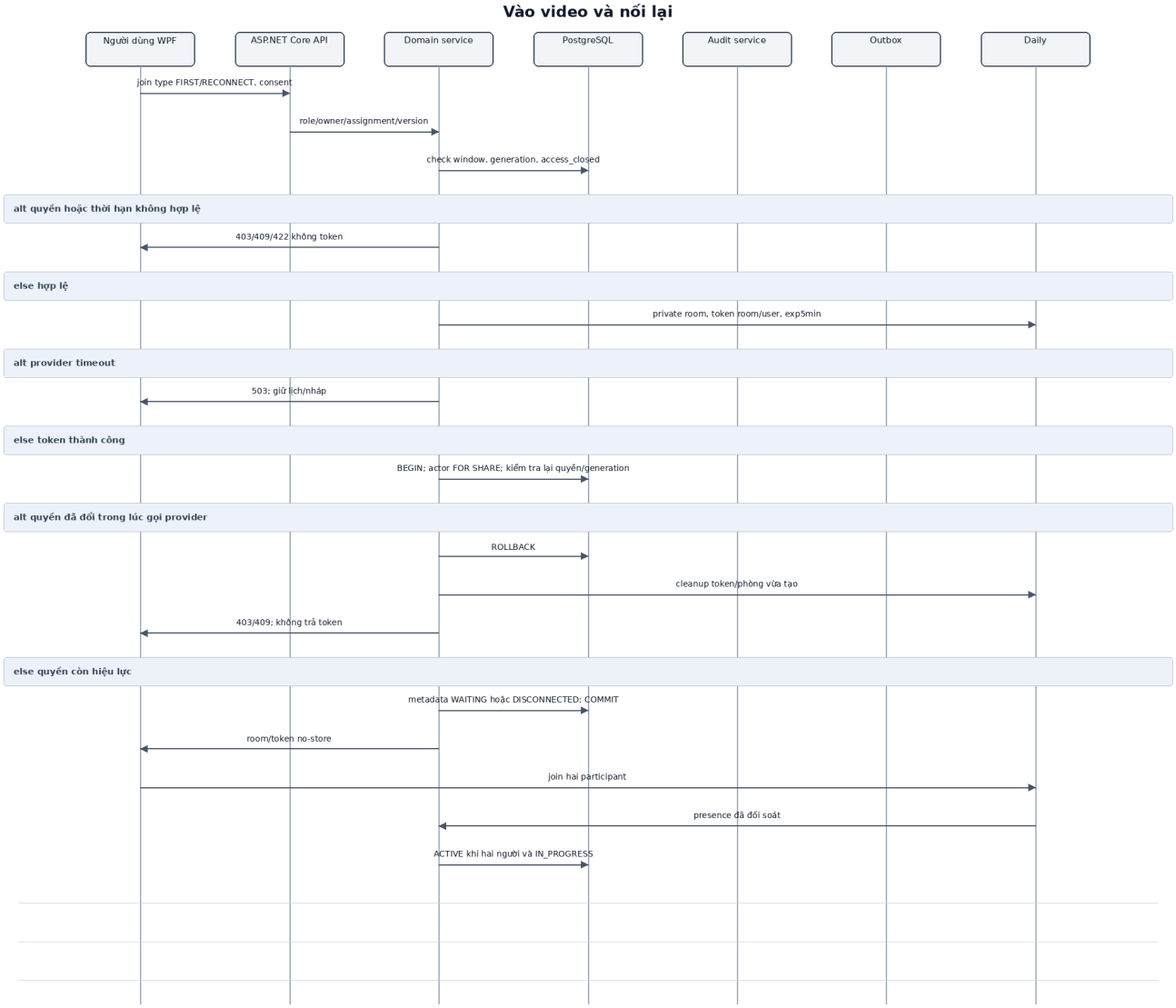
Hình 17 Đọc và xuất PHI theo quyền UML-SEQ-PHIREAD



Hình 17 biểu diễn đọc và xuất phi theo quyền.

7.6 Tham gia và nối lại video

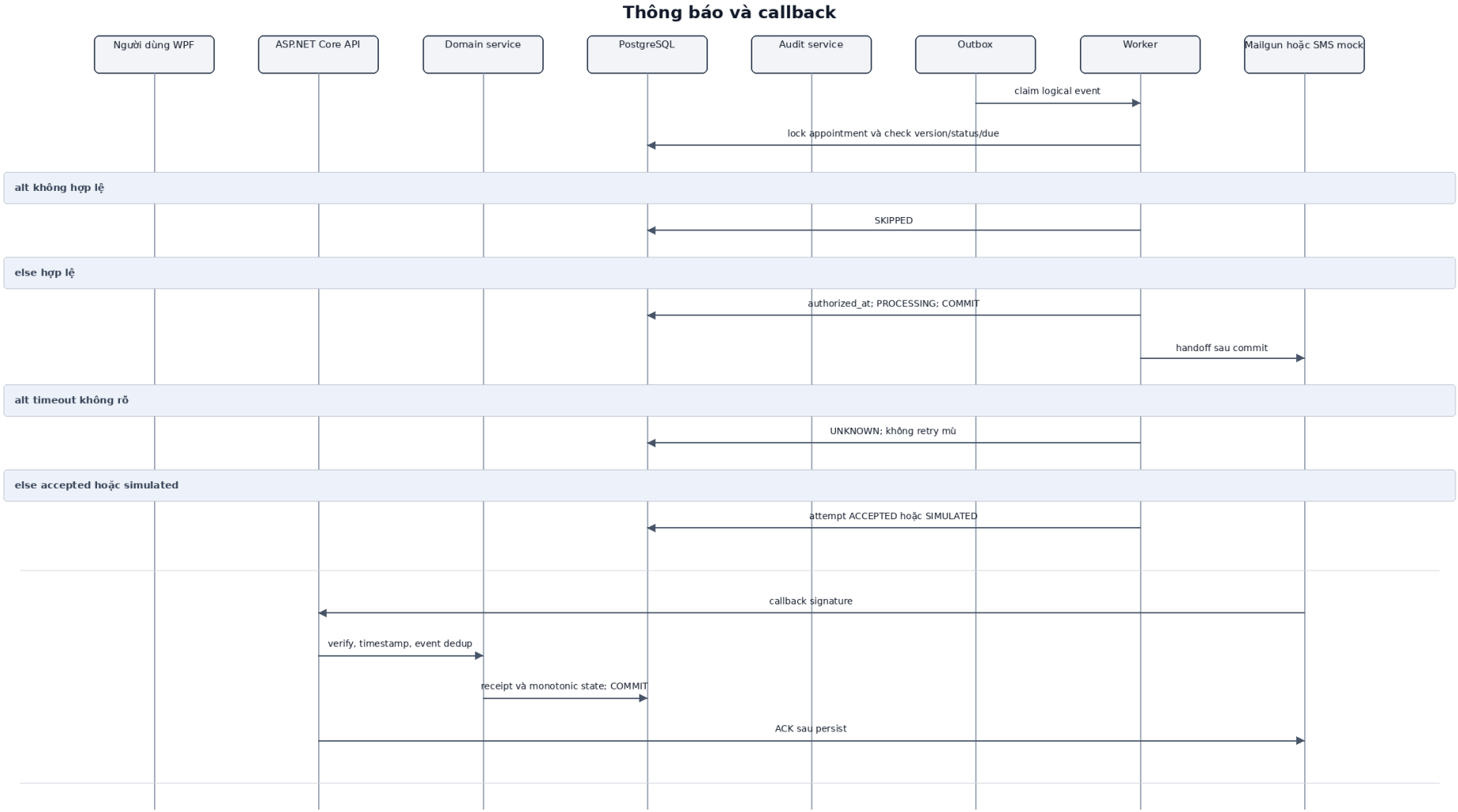
Hình 18 Vào video và nối lại UML-SEQ-VIDEO



Hình 18 biểu diễn vào video và nối lại.

7.7 Thông báo và callback

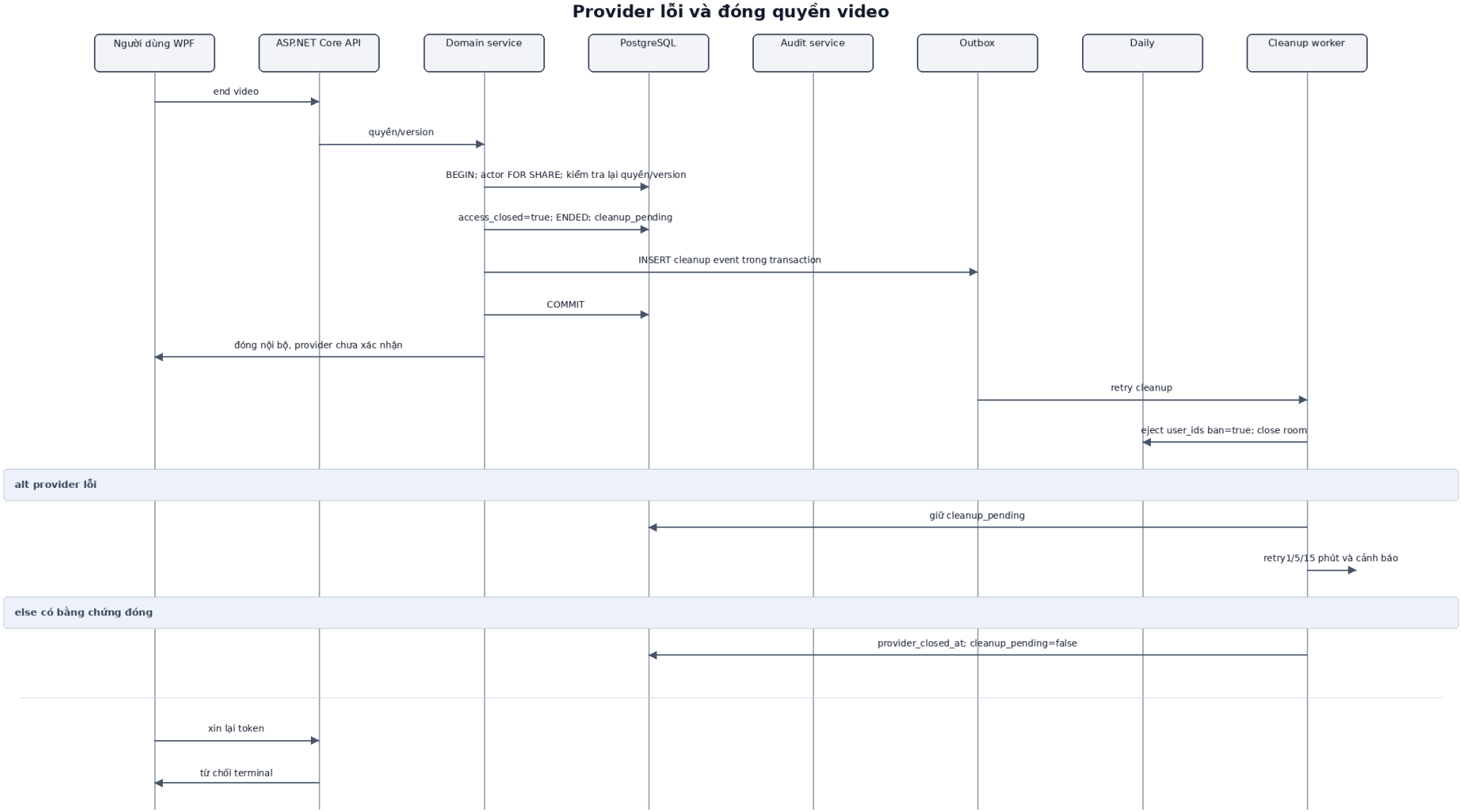
Hình 19 Thông báo và callback UML-SEQ-NOTIFY



Hình 19 biểu diễn thông báo và callback.

7.8 Đóng video khi provider lỗi

Hình 20 Provider lỗi và đóng quyền video UML-SEQ-FAILURE



Hình 20 biểu diễn provider lỗi và đóng quyền video.

Finalize và đọc PHI/export có sequence riêng vì biên audit khác nhau. Ghi audit cùng mutation transaction; đọc audit commit trước giải mã/trả byte dữ liệu. Trong reschedule, không trả chỗ cũ trước khi giữ chỗ mới trong cùng transaction. Check-in/cancel/start dùng cùng khóa appointment, version đọc lại; state không hợp lệ trả 409.

8 Bảo mật và riêng tư

8.1 Quyền theo quan hệ

Pipeline: request_id → rate limit → auth → account/authz_version → scope → policy(resource owner/branch/care/time/status) → validate → transaction → kiểm tra quyền hiện tại → audit → response. SQL query áp scope ở repository; không fetch mọi dữ liệu rồi lọc trong UI. ClinicalPolicy kiểm tra CareAssignment hiện hành và tác giả. Doctor HISTORICAL chỉ record/đơn của encounter đã phụ trách; không cấp quyền đọc toàn bộ health profile. Tác giả inactive dùng kích hoạt có thời hạn, không impersonation.

8.2 Dữ liệu và khóa

PHI và PDF riêng tư dùng AES-256-GCM từ thư viện chuẩn .NET, có key_id thuộc key ring riêng ngoài DB; khóa được luân phiên và quản lý riêng với OAuth signing keys. Không log body/query sức khỏe; không PHI trong Preferences, Windows DPAPI (ProtectedData) (ngoại trừ token), analytics, crash reports hoặc cache app; API trả Cache-Control: no-store và thực thi audit trước đọc PHI.

Keys nằm trong secret mount quyền đọc tối thiểu, không trong image/Git/DBdump. Rotation đặt key mới cho dữ liệu mới và draft, giữ khóa cũ cho FINAL và backup. Tệp được tạo lại có thể dùng khóa mới; không rewrite bản FINAL để rotate. Khóa phục hồi có bản riêng kiểm soát truy cập, không bỏ cùng archive dữ liệu. Khi key thiếu/decrypt thất bại, trả 503 không plaintext fallback.

8.3 Ứng dụng WPF, API và tệp đính kèm

API dùng JSON serializer/validation allowlist và truy vấn tham số hóa qua Npgsql/EF Core; ViewModel không tin input owner/doctor/status, mọi quyền kiểm ở API. Microsoft Edge WebView2 dành riêng video phải hạn chế điều hướng/origin, không nhúng trang đăng nhập OAuth, yêu cầu permission mic/camera theo Windows desktop; API dùng HSTS, TLS, CORS hẹp cho callback web nếu cần. PDF sinh server, tải qua endpoint phân quyền và không lưu tự động vào thư mục công khai client.

8.4 Video và webhook

Daily room privacy=private, roomname ngẫu nhiên, max_participants=2. Token có room_name, user_id, exp≤now+5 phút, is_owner=false; expiry dùng cho quyền join, eject_at_token_exp=false để không cắt cuộc khám mỗi năm phút. Không bật recording ở account/room/UI; không triển khai endpoint recording. Khi end/cancel/reschedule, access_closed ngay, generation cũ không được cấp lại; eject(user_ids, ban=true) và đóng room sau commit. Provider down thì cleanup_pending, retry hữu hạn và cảnh báo; media hiện hữu có giới hạn đóng phụ thuộc provider, không tuyên bố thu hồi vật lý tức thì.

Mailgun receiver kiểm HMAC SHA256(timestamp+token) constant-time, timestamp không quá 24 giờ và token/event_id dedup7 ngày, đối chiếu message_id. Daily receiver dùng BasicAuth bí mật riêng HTTPS theo API đăng ký; event và room đối chiếu REST trước tác động nhạy cảm. Raw payload không ghi log; receipt giữ digest. Receipt và cập nhật được lưu bền vững trước ACK; DB lỗi503 cho provider retry. Callback đến đảo thứ tự không lùi DELIVERED; callback không làm FINAL hoặc cấp quyền phòng.

8.5 Audit và log vận hành

AuditEvent ghi actor/role/patient/resource/action/outcome/UTC/request_id/source_digest. App chỉ INSERT/SELECT với lịch sử audit và không có UI sửa/xóa. Append lấy audit head theo ngày, tăng sequence và HMAC chuỗi cùng transaction; daily digest sao chép ngoài VPS. Technical log chứa mã lỗi và correlation, không thay audit bệnh nhân. Denied phải từ chối cả khi audit unavailable; lỗi kỹ thuật

ghi riêng. Alerthơn 30 hồ sơ trong 5 phút hoặchơn 10 yêu cầu denied trong 5 phút là cảnh báo metadata, không tự khóa hoặc kết luận vi phạm.

9 Thiết kế giao diện

UI-01 Tài khoản

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Email, mật khẩu, xác minh, quên/đổi mật khẩu, đăng xuất.

Dữ liệu và hành động Đăng ký, đăng nhập, gửi lại, reset, đổi mật khẩu, logout. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Mật khẩu từ 12 đến 128 ký tự; email chuẩn; phản hồi chung, đếm ngược thời gian thử lại khi HTTP 429. UI-01 không cấp vai trò staff từ dropdown công khai.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-02 Hồ sơ và sức khỏe

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Hành chính, mã BN, tự khai, phần chuyên môn có nguồn, history.

Dữ liệu và hành động Sửa chính hồ sơ, tự khai; bác sĩ xác minh trong ca. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Ngày sinh không sau ngày hiện tại; UNKNOWN/NONE/KNOWN; version và audit. Bệnh nhân không sửa chuyên môn; lễ tân chỉ hành chính.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-03 Tìm lịch trống

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Chi nhánh, chuyên khoa, bác sĩ, mode, ngày giờ, slot.

Dữ liệu và hành động Lọc và chọn slot. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Cửa sổ 30 ngày; slot hiển thị không giữ chỗ. Công khai chỉ thông tin bác sĩ/slot, không người đã đặt.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-04 Lịch hẹn

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Tóm tắt giờ, nơi, mode, quy tắc, mã lịch, history, version.

Dữ liệu và hành động Đặt, đổi, hủy, xem lịch. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Key chống lặp; lý do; ngưỡng 120 phút; HTTP 409 yêu cầu tải lại. Bệnh nhân chính chủ; nhân viên đúng quan hệ và chi nhánh.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-05 Lịch bác sĩ

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Ca ngày/tuần, nghỉ, mode, chi nhánh, hàng chờ.

Dữ liệu và hành động Công bố ca, thông báo nghỉ, chọn bắt đầu. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Kiểm tra giao nhau và khoảng chuyển chi nhánh 60 phút; stop_booking; doctor_busy. Bác sĩ chính lịch mình; lễ tân phạm vi; admin cấu hình.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-06 Tiếp nhận

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Tìm hành chính, lịch hôm nay, WAITING, UNRESOLVED, đến muộn.

Dữ liệu và hành động Tạo hồ sơ, walk-in, check-in, cancel-check-in, no-show, điều phối. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền -15 phút;+15 phút cần lý do; đồng ý thay lịch; tranh chấp trả HTTP 409. Lễ tân chi nhánh; không bảng PHI lâm sàng.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-07 Khám và đơn nháp

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Tiền sử, dị ứng nguồn, ghi khám, dòng thuốc, version, giờ lưu.

Dữ liệu và hành động Lưu nháp, xác minh, xử lý cảnh báo, hoàn tất, gián đoạn. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Thiếu trường gắn input; dirty-state; audit lỗi trả HTTP 503; version cũ trả HTTP 409. Chỉ bác sĩ ca IN_PROGRESS; không PHI localStorage.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-08 Kết quả và hiệu chỉnh

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. FINAL gốc, addendum, đơn hiện hành và chuỗi, nhãn demo.

Dữ liệu và hành động Xem/tải, bác sĩ tác giả bổ sung/thay đơn. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Reason/version; trạng thái SUPERSEDED rõ; tải riêng tư. Bệnh nhân chỉ xem FINAL của mình; bác sĩ chỉ ca đã phụ trách; admin/lễ tân không.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-09 Video

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Kiểm tra thiết bị, consent, room chờ, hai participant, mất kết nối, cleanup.

Dữ liệu và hành động Vào, bác sĩ nhận/bắt đầu, nối lại, kết thúc, hướng dẫn DIRECT. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền -10 phút; token 5 phút; nối lại10 phút; terminal chặn. Chỉ hai người đúng ca; không nút recording; nút kết thúc khác hoàn tất.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-10 Thông báo

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Danh sách kênh/sự kiện, due, attempts, accepted/delivered/unknown/simulated.

Dữ liệu và hành động Xem, đối soát UNKNOWN bằng bằng chứng. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Không retry mù; tối đa ba lần gửi; nội dung chỉ lịch. Bệnh nhân xem lịch của mình; bác sĩ xem ca được giao; lễ tân đúng chi nhánh; admin chỉ metadata.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-11 Quản trị

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Nhân sự, chi nhánh, chuyên khoa, cấu hình mẫu, authz version.

Dữ liệu và hành động Tạo/sửa/inactive; kích hoạt tác giả có hạn; cấu hình. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Admin cuối; lịch tương lai; version; reason. Admin không có nút bệnh án; không giả danh.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

UI-12 Nhật ký và vận hành

Bố cục và thành phần Cửa sổ Windows có tiêu đề, nội dung chính và vùng hành động; cửa sổ hẹp dùng bố cục thích ứng. Audit metadata, bộ lọc, alert, digest và trạng thái backup.

Dữ liệu và hành động Tra, xuất tối đa 10 000 dòng, đánh đã xem; runbook hạ tầng riêng. Dữ liệu server theo owner/branch/doctor policy, hiển thị version nếu sửa.

Validation và quyền Bộ lọc; phân trang tối đa 100; lỗi log chặn truy cập; không PHI; checksum. Admin chỉ metadata; backup/restore không có nút HTTP.

Loading và empty Đang tải có nhãn văn bản và khóa nút gửi; empty nêu chưa có dữ liệu và thao tác phù hợp, không gọi lỗi mạng là danh sách rỗng.

Error và success 422 chỉ rõ trường;409 giữ nội dung trên màn hình và yêu cầu tải lại;401 đăng nhập lại;503 không báo đã lưu. Success chỉ sau server commit, hiện mã/version/thời điểm cần thiết.

Tiếp cận Label cho mỗi input, focus tới lỗi đầu, Tab theo thứ tự, trạng thái bằng chữ; bảng DataGrid WPF có thể cuộn, focus bằng bàn phím và thao tác xác nhận có lý do. Không dùng màu là dấu hiệu duy nhất.

10 Triển khai và vận hành

Solution Visual Studio: Clinic.sln có Clinic.Desktop (WPF: Views, ViewModels, Commands, Services, Security, Video/WebView2), Clinic.Api (ASP.NET Core Controllers/Middleware), Clinic.Domain, Clinic.Application, Clinic.Infrastructure (EF Core/Npgsql/OpenIddict/adapters), Clinic.Worker (.NET BackgroundService), Clinic.Tests.Unit, Clinic.Tests.Unit, Clinic.Tests.Api (FlaUI).

10.1 Runbook ứng dụng WPF và backend API

1. Chốt commit SHA; dùng dotnet restore bình thường ở scaffold, chỉ dùng --locked-mode sau khi commit packages.lock.json; chạy dotnet build, dotnet format, Roslyn analyzers, NuGet vulnerability audit, xUnit coverage (≥60%), PostgreSQL integration và OpenAPI contract.

2. Chuẩn bị Linux API host (ví dụ VPS Ubuntu 24.04), firewall 80/443/SSH giới hạn; Docker private network không public DB port 5432, reverse proxy Nginx với TLS; có thể demo API trong LAN HTTPS nếu đáp ứng kiểm chứng.

3. Cấp PHI key ring, OAuth signing/encryption keys, Mailgun/Daily secrets và restic password từ secret store/server environment; tuyệt đối không đóng gói server secret trong WPF/MSIX/installer.

4. Publish ASP.NET Core Kestrel API (container Linux), .NET Worker Service/scheduler, PostgreSQL 17, reverse proxy; đặt ASPNETCORE_ENVIRONMENT=Production, tắt developer exception page và giới hạn CORS.

5. Chạy EF Core migrations (Identity/OpenIddict) cùng DDL domain PostgreSQL theo thứ tự; cấp runtime role riêng; seed dữ liệu giả, admin test và đăng ký public native OAuth client với PKCE/redirect URI chính xác.

6. Đăng ký Mailgun webhook và Daily webhookBasic Auth qua HTTPS; Daily private room/account không recording. SmsMockAdapter chỉ SIMULATED.

7. Chạy health/live và internal readiness DB/queue/storage/keys; scheduler heartbeat≤2 phút; worker lease và backlog; đối chiếu notification nhắc trước 24 giờ và 2 giờ bằng clock fixture.

8. Smoke chín phân hệ với bốn role/hai chi nhánh trên Windows 10/11; xác minh WebView2 permission/video hai mạng, PHI audit, file PDF, SMS mock và Email callback.

9. Tạo backup mãhóa ngoàiVPS và restore vào DB riêng; đoRPO/RTO; đối chiếuFK/count/digest vàgiải mã mẫu.

10. Build Release WPF bằng Visual Studio, tạo MSIX hoặc installer Windows, ký mã và lưu SHA/hash; ghi Windows/.NET Desktop Runtime/WebView2 version, API URL và báo cáo test; demo bằng ứng dụng cài được, không dùng URL ví dụ.

10.2 Giám sát và phục hồi

Probe /health mỗi phút; readiness kiểm DB/key nội bộ; cảnh báo backlog >5 phút, health 3 lỗi/backup fail. Worker restart bằng container. WPF hiển thị offline/retry an toàn, không xác nhận thành công khi API chưa commit.

Backup bằngpg_dump nhấtquán và private files mã hóa, resticarchive giữ bảy bản gần nhất VERIFIED; không xóa bản cuối khi mới FAILED. Restore thiếu khóa/checksum dừng trước cutover; phục hồi vào DB riêng, health vàsample decrypt rồi chuyển service. Rollbackcode giữ schema tương thích; không dùng DROP migration để mất lịch sử. Operator giữrun log tách khỏi audit bệnh nhân.

11 Kiểm thử thiết kế và điểm giới hạn

Thiết kế có thể kiểm chứng qua policy unit, PostgreSQL integration thật nhiều kết nối, API schema/response và E2E. SQL parser không chứng minh constraint runtime; schema OpenAPI hợp lệ không chứng minh controller đã triển khai. NFR 50 người dùng, năm phiên video, khả dụng 99%, RPO và RTO là mục tiêu cần đo. Provider down làm cleanupmedia không xác nhận; hệ thống chặn quyền nội bộ và bảo toàn dữ liệu. Demo không là bằng chứng hệ thống phù hợp dùng khám thật.

Tài liệu tham chiếu

SRC-01 Tuần 1 Topics CNPM sources/Tuần 1-Topics-CNPM.pdf
Topic 2 và Handbook chấm đồ án: OAuth2, video, nhắc lịch, PHI audit; bốn vai trò và coverage tối thiểu 60%.

SRC-02 Tuần 1 CNPM sources/Tuần 1-CNPM.pdf
Quy trình và hồ sơ kỹ nghệ phần mềm.

SRC-03 Slides tuần 2 và 3 sources/2-3.Slides.pdf
Agile, Scrum và user story.

SRC-04 Slides tuần 4 sources/4.Slides.pdf
Khai thác, lượng hóa và phân loại yêu cầu.

SRC-05 Slides tuần 5 sources/5.Slides.pdf
Use case và UML yêu cầu.

SRC-06 Slides tuần 6 và 7 sources/6-7.Slides.pdf
Kiến trúc, thiết kế, UML và dữ liệu.

SRC-07 Mẫu y tế tuần 6 và 7 sources/CNPM_Y_tế_T6_7.pdf
Tham khảo cách tổ chức thiết kế; không sao chép nghiệp vụ khác.

SRC-08 Đặc tả nghiệp vụ ban đầu HỆ THỐNG ĐẶT LỊCH KHÁM & KHÁM BỆNH (1).docx
Đối tượng và nghiệp vụ phòng khám; tái cấu trúc theo MVP.

SRC-09 Repository baseline https://github.com/Samie32/SE-project/tree/main
SHA 85cc9fd1e51d663a734da7155c039ab46e0f615b; scaffolding và README; không có sản phẩm kiểm thử.

SRC-10 ISO IEC IEEE 29148 https://www.iso.org/standard/72089.html
Tổ chức yêu cầu, nguồn, thuộc tính và kiểm chứng; cấu trúc EARS dùng cho phát biểu.

SRC-11 UML 2.5.1 OMG https://www.omg.org/spec/UML/2.5.1
Use case, activity, state, sequence, class, component và deployment.

SRC-12 OpenAPI 3.1.1 https://spec.openapis.org/oas/v3.1.1.html
Schema JSON Schema 2020-12 và hợp đồng API.

SRC-13 Microsoft WPF, WebView2 và ASP.NET Core
https://learn.microsoft.com/dotnet/desktop/wpf/overview/
C#/.NET Windows desktop với XAML/MVVM; video runtime:
https://learn.microsoft.com/microsoft-edge/webview2/ ; API:
https://learn.microsoft.com/aspnet/core/ .

SRC-14 PostgreSQL17 Range https://www.postgresql.org/docs/17/rangetypes.html
Range và exclusion constraint.

SRC-15 OAuth2 Security BCP https://www.rfc-editor.org/info/rfc9700/
Authorization Code, PKCE, redirect và chống replay.

SRC-16 PKCE RFC7636 https://www.rfc-editor.org/info/rfc7636/
code_verifier/code_challenge S256.

SRC-17 Daily rooms và tokens https://docs.daily.co/reference/rest-api/meeting-tokens/create-meeting-token
room_name, user_id, exp, eject_at_token_exp; token expiry khác độ dài cuộc gọi.

SRC-18 Daily eject ban https://docs.daily.co/reference/rest-api/rooms/session/eject
Eject theo user_ids và ban chống vào lại.

SRC-19 Daily webhook Basic Auth https://docs.daily.co/reference/rest-api/webhooks/create-webhook
Callback đăng ký Basic Auth qua HTTPS và chống lặp ở adapter.

SRC-20 Mailgun webhook
https://documentation.mailgun.com/docs/mailgun/user-manual/webhooks/webhook-payloads
Signature timestamp/token và metadata sự kiện.

SRC-21 Mailgun SDK signing https://github.com/mailgun/mailgun-go/blob/main/webhooks.go
HMAC SHA256 của timestamp+token; constant-time comparison.

SRC-22 DigitalOcean Droplets https://docs.digitalocean.com/products/droplets/details/features/ Máy chủ Linux và backup; lựa chọn cấu hình là quyết định đồ án.

SRC-23 OWASP ASVS https://owasp.org/www-project-application-security-verification-standard/ Checklist auth, access control, crypto, input, session; không tuyên bố chứng nhận.

12 Phụ lục kiến trúc ứng dụng Visual Studio (phiên bản 2.1)

12.1 Các dự án trong solution

Clinic.Desktop là dự án WPF .NET 10 (Views, ViewModels, HttpClients, Services, Security/DPAPI, WebView2); Clinic.Api sử dụng ASP.NET Core, Clinic.Application/Domain tách độc lập UI/EF Core; Worker dùng BackgroundService; dự án Unit/Integration/AppUI dùng xUnit/FlaUI.

12.2 Biên giới an toàn

WPF Windows → HTTPS Bearer → ASP.NET Core API → application/domain policies → PostgreSQL 17. App không chứa connection string DB, khóa mã hóa PHI, provider secrets hay signing keys. API cấp video token có giới hạn sau khi kiểm tra lịch/role/consent.

12.3 API/OAuth compatibility

Hợp đồng OpenAPI 2.3 có 80 operations: xóa ba endpoint legacy /auth/login, /auth/csrf và /auth/callback (cập nhật RTM) và thêm /oauth/revoke. WPF clinic-wpf thực hiện Authorization Code + PKCE S256 qua browser hệ thống và nhận code trên loopback 127.0.0.1/cổng động; client public không có client secret. API nghiệp vụ Bearer token, không BFF cookie hoặc CSRF. Kiểm chứng thực tế redirect allowlist của OpenIddict vẫn là việc cần làm.

12.4 Triển khai và vận hành

CI: dotnet restore/build/test, xUnit/coverlet (scaffold mới kiểm gate 60% trong Clinic.Domain; chưa chứng minh 60% toàn phần mềm) và Microsoft Playwright APIRequest integration test chạy với ASP.NET Core API trên Ubuntu; kiểm thử DB PostgreSQL cần service DB. FlaUI WPF UI tests chạy ở Windows agent có desktop tương tác, không dùng Playwright browser để tự động hóa UI WPF. Backend Docker Compose; đóng MSIX có ký khi release.

12.5 Rủi ro cần kiểm chứng

Spike Daily trong WPF WebView2: WebRTC, camera/micro allow/deny, autoplay, resize/Focus, reconnect/cleanup, cập nhật Edge WebView2 Runtime. OAuth loopback 127.0.0.1+cổng động, chống redirect hijack, token DPAPI theo user và logout/restart. Các phần này chưa có log thực nghiệm.

ADR-2.3: API, dữ liệu và kiểm thử WPF

API 2.3: /oauth/authorize, /oauth/token, /oauth/revoke do OpenIddict xử lý (identity-hosted); /auth/logout là API Bearer xử lý thu hồi authorization/version ở server. Browser identity form có thể sử dụng cookie nội bộ riêng của máy chủ nhưng không cấp cookie cho WPF API. OpenAPI 80 operations; RTM phải phản ánh operation mới và không chứa các operationId legacy.

EF Core được chọn cho CRUD và mapping thực thể, migration Identity/OpenIddict. Dùng ADO.NET Npgsql parameterized commands cho SQL lock chuyên biệt (SELECT ... FOR UPDATE, SKIP LOCKED), transaction boundary, retry SQLSTATE 23P01 trên exclusion constraint và lease worker; không triển khai cùng một transaction nếu không chia sẻ DbConnection/DbTransaction.

Unit xUnit + coverlet kiểm policy; Playwright .NET APIRequest gọi API thật để kiểm HTTP contract/auth errors và chống lộ PHI; không dùng Playwright browser để điều khiển WPF. FlaUI dành cho Windows UI automation; kiểm thử video WebView2+Daily và OpenIddict PKCE loopback là technical spike bắt buộc.

Hạ tầng reverse proxy thống nhất Nginx. Compose chỉ là môi trường phát triển; triển khai production cần chứng chỉ TLS và secret store. Mọi kết quả kiểm thử chưa có execution log tiếp tục NOT_RUN.